

Audit Report

3. Detailed Audit Controls

3.1. Information Technology (IT) Security Guidelines

3.1.1. Implementation of Information Security

Control No.	Control	Audit Checks	Control Type	References	Compliance	D
Security Policy						
3.1.1.1	An information security policy document has been formulated that includes physical, personnel, procedural and technical controls and was submitted to the Controller before commencement of operation.	- Obtain the softcopy/hardcopy of the information security policy - Check the following - Controller received the policy approved by CA management before commencing operations - Policy contains physical, personnel, procedural and technical controls - information is classified depending upon its sensitivity for the CA as per IT Act-2000 - both confidential and non-confidential information addressed in the policy - CA has prepared detailed manuals for performing its activities - CA ensures security and risk management controls are implemented - policy has been approved by CA management. Verify by checking approval date. - policy has been communicated to all employees via mail or training session - Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined - verify roles and responsibilities defined - Verify the all recent changes done to the policy since last audit - For sample recent changes done to the policy validate details were submitted to Controller within two weeks	Mandatory	IT CA Rules 19.2	Yes	3
3.1.1.2	CA shall ensure the security policy clearly addresses security of both confidential and non-confidential information. The Certifying Authority shall prepare detailed manuals for performing all its activities and shall scrupulously adhere to them.	- Obtain the softcopy/hardcopy of the information security policy - Check the following - Controller received the policy approved by CA management before commencing operations - Policy contains physical, personnel, procedural and technical	Mandatory	WebTrust 3.9.5, IT Regulations 3	No	3

		controls information is classified depending upon its sensitivity for the CA as per IT Act-2000 both confidential and non-confidential information addressed in the policy CA has prepared detailed manuals for performing its activities CA ensures security and risk management controls are implemented policy has been approved by CA management. Verify by checking approval date. policy has been communicated to all employees via mail or training session Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined verify roles and responsibilities defined Verify the all recent changes done to the policy since last audit For sample recent changes done to the policy validate details were submitted to Controller within two weeks			
3.1.1.3	The Certifying Authority shall as approved, in respect of security and risk management controls continuously ensure that security policies and safeguards are in place. Such controls include personnel security and incident handling measures to prevent fraud and security breaches. The security policy shall be approved by management,	Obtain the softcopy/hardcopy of the information security policy Check the following Controller received the policy approved by CA management before commencing operations Policy contains physical, personnel, procedural and technical controls information is classified depending upon its sensitivity for the CA as per IT Act-2000 both confidential and non-confidential information addressed in the policy CA has prepared detailed manuals for performing its activities CA ensures security and risk management controls are implemented policy has been approved by CA management. Verify by checking approval date. policy has been communicated to all employees via mail or training session Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined verify roles and responsibilities defined	Mandatory	IT Regulations 3, WebTrust 3.1.1	

		defined - Verify the all recent changes done to the policy since last audit - For sample recent changes done to the policy validate details were submitted to Controller within two weeks 			
3.1.1.4	<p>The Certifying Authority shall as approved, in respect of security and risk management controls continuously ensure that security policies and safeguards are in place. Such controls include personnel security and incident handling measures to prevent fraud and security breaches. The security policy shall be approved by management,published and communicated to all employees.
</p>	- Obtain the softcopy/hardcopy of the information security policy - Check the following - Controller received the policy approved by CA management before commencing operations - Policy contains physical, personnel, procedural and technical controls - information is classified depending upon its sensitivity for the CA as per IT Act-2000 - both confidential and non-confidential information addressed in the policy - CA has prepared detailed manuals for performing its activities - CA ensures security and risk management controls are implemented - policy has been approved by CA management. Verify by checking approval date. - policy has been communicated to all employees via mail or training session - Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined - verify roles and responsibilities defined - Verify the all recent changes done to the policy since last audit - For sample recent changes done to the policy validate details were submitted to Controller within two weeks 	Mandatory	IT Regulations 3, WebTrust 3.1.1	
3.1.1.5	<p>An authorized personnel shall be responsible for ensuring that security procedures within their area of responsibility are carried out correctly
</p>	- Obtain the softcopy/hardcopy of the information security policy - Check the following - Controller received the policy approved by CA management before commencing operations - Policy contains physical, personnel, procedural and technical controls - information is classified depending upon its sensitivity for the CA as per IT Act-2000 - both confidential and non-confidential information addressed in the policy - CA has prepared	Mandatory	WebTrust 3.9.8	

		detailed manuals for performing its activities - CA ensures security and risk management controls are implemented - policy has been approved by CA management. Verify by checking approval date. - policy has been communicated to all employees via mail or training session - Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined - verify roles and responsibilities defined - Verify the all recent changes done to the policy since last audit - For sample recent changes done to the policy validate details were submitted to Controller within two weeks			
3.1.1.6	A review process shall be designed for maintaining the security policy. Review dates and responsibilities should be recorded.	- Obtain the softcopy/hardcopy of the information security policy - Check the following - Controller received the policy approved by CA management before commencing operations - Policy contains physical, personnel, procedural and technical controls - information is classified depending upon its sensitivity for the CA as per IT Act-2000 - both confidential and non-confidential information addressed in the policy - CA has prepared detailed manuals for performing its activities - CA ensures security and risk management controls are implemented - policy has been approved by CA management. Verify by checking approval date. - policy has been communicated to all employees via mail or training session - Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined - verify roles and responsibilities defined - Verify the all recent changes done to the policy since last audit - For sample recent changes done to the policy validate details were submitted to Controller within two weeks	Mandatory	WebTrust 3.1.3	

3.1.1.7	Any change made by the Certifying Authority in the security policy shall be submitted by it within two weeks to the Controller	- Obtain the softcopy/hardcopy of the information security policy - Check the following - Controller received the policy approved by CA management before commencing operations - Policy contains physical, personnel, procedural and technical controls - information is classified depending upon its sensitivity for the CA as per IT Act-2000 - both confidential and non-confidential information addressed in the policy - CA has prepared detailed manuals for performing its activities - CA ensures security and risk management controls are implemented - policy has been approved by CA management. Verify by checking approval date. - policy has been communicated to all employees via mail or training session - Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined - verify roles and responsibilities defined - Verify the all recent changes done to the policy since last audit - For sample recent changes done to the policy validate details were submitted to Controller within two weeks	Mandatory	IT CA Rules 19		
3.1.1.8	Test	- Obtain the softcopy/hardcopy of the information security policy - Check the following - Controller received the policy approved by CA management before commencing operations - Policy contains physical, personnel, procedural and technical controls - information is classified depending upon its sensitivity for the CA as per IT Act-2000 - both confidential and non-confidential information addressed in the policy - CA has prepared detailed manuals for performing its activities - CA ensures security and risk management controls are implemented - policy has been approved by CA management. Verify by checking approval date. - policy has been	Optional	Test		

		communicated to all employees via mail or training session - Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined - verify roles and responsibilities defined - Verify the all recent changes done to the policy since last audit - For sample recent changes done to the policy validate details were submitted to Controller within two weeks 				
3.1.1.9	Test2 	- Obtain the softcopy/hardcopy of the information security policy - Check the following - Controller received the policy approved by CA management before commencing operations - Policy contains physical, personnel, procedural and technical controls - information is classified depending upon its sensitivity for the CA as per IT Act-2000 - both confidential and non-confidential information addressed in the policy - CA has prepared detailed manuals for performing its activities - CA ensures security and risk management controls are implemented - policy has been approved by CA management. Verify by checking approval date. - policy has been communicated to all employees via mail or training session - Obtain name of personnel responsible for ensuring that security procedures implementation and verify roles and responsibilities defined - verify roles and responsibilities defined - Verify the all recent changes done to the policy since last audit - For sample recent changes done to the policy validate details were submitted to Controller within two weeks 	Optional	Hello		
Self-Assessment						
3.1.1.10	A documented security self-assessment plan shall be prepared by the CA 	<p>1. Obtain the self-assessment plan developed by the CA 2. Verify on a sample basis the for last two self-assessments conducted 3. Collect report of	Mandatory	IT CA Rules 2.e		

		the self-assessment plan 4. Check the following: a. Findings of self-assessment were shared with the management b. Action was taken to address the finding				
3.1.1.11	Self-Assessment shall be performed on a periodic basis and the findings shall be reported to management and discussed for closure	1. Obtain the self-assessment plan developed by the CA 2. Verify on a sample basis the for last two self-assessments conducted 3. Collect report of the self-assessment plan 4. Check the following: a. Findings of self-assessment were shared with the management b. Action was taken to address the finding	Mandatory	IT CA Rules 2.e		
Risk Assessment						
3.1.1.12	The CA's security program shall include an annual Risk Assessment	1. Obtain copy of annual Risk Assessment plan 2. Check the following: a. Threats are identified and documented as part of risk assessment b. Standard operating procedures are present for combating threats. c. controls are in place to prevent misuse, alteration and destruction of sensitive information d. adequate cyber security tools are implemented by the CA such as DLP, Web Gateway, Email Gateway, Proxy Servers, and Firewalls, SSL/TLS, IDS/IPS, SAST, DAST, etc. e. a vulnerability assessment by the above mentioned tools are carried out at a pre decided interval. Report any scheduled VA left out. f. security plan has been developed g. updates and patches are applied in timely manner 3. Check the security plan covers the following safeguards: a. administrative, b. organizational, c. technical, and d. physical 4. Verify formal change management procedures have been developed	Mandatory	IT CA Rules SCHEDULE-II 17.3 CA Browser Forum 5		
3.1.1.13	A list of foreseeable internal and external threats that could result in unauthorized access, disclosure, misuse, alteration, or destruction of any critical information shall be maintained.	1. Obtain copy of annual Risk Assessment plan 2. Check the following: a. Threats are identified and documented as part of risk assessment b. Standard operating procedures are present for combating threats. c. controls are in place to prevent misuse, alteration and destruction of sensitive information d. adequate cyber security tools are implemented by the CA such as DLP, Web Gateway, Email Gateway, Proxy Servers, and Firewalls, SSL/TLS, IDS/IPS, SAST, DAST, etc. e. a vulnerability assessment by the above mentioned	Mandatory	CA Browser Forum 5		

		tools are carried out at a pre decided interval. Report any scheduled VA left out.
f. security plan has been developed
g. updates and patches are applied in timely manner
3. Check the security plan covers the following safeguards:
a. administrative,
b. organizational,
c. technical, and
d. physical
4. Verify formal change management procedures have been developed
</p>				
3.1.1.14	<p>The sufficiency of the policies, procedures, information systems, technology, and other arrangements that the CA has in place to counter cyber threats shall be verified.
</p>	<p>1. Obtain copy of annual Risk Assessment plan
2. Check the following:
a. Threats are identified and documented as part of risk assessment
b. Standard operating procedures are present for combating threats.
c. controls are in place to prevent misuse, alteration and destruction of sensitive information
d. adequate cyber security tools are implemented by the CA such as DLP, Web Gateway, Email Gateway, Proxy Servers, and Firewalls, SSL/TLS, IDS/IPS, SAST, DAST, etc.
e. a vulnerability assessment by the above mentioned tools are carried out at a pre decided interval. Report any scheduled VA left out.
f. security plan has been developed
g. updates and patches are applied in timely manner
3. Check the security plan covers the following safeguards:
a. administrative,
b. organizational,
c. technical, and
d. physical
4. Verify formal change management procedures have been developed
</p>	Mandatory	CA Browser Forum 5		
3.1.1.15	<p>A security plan shall be developed covering the following:
• Security procedures to manage the risks
• administrative, organizational, technical, and physical safeguards
• cost of implementing the specific measures
• security breach plan in case of any incidents
</p>	<p>1. Obtain copy of annual Risk Assessment plan
2. Check the following:
a. Threats are identified and documented as part of risk assessment
b. Standard operating procedures are present for combating threats.
c. controls are in place to prevent misuse, alteration and destruction of sensitive information
d. adequate cyber security tools are implemented by the CA such as DLP, Web Gateway, Email Gateway, Proxy Servers, and Firewalls, SSL/TLS, IDS/IPS, SAST, DAST, etc.
e. a vulnerability assessment by the above mentioned tools are carried out at a pre decided interval. Report any scheduled VA left out.
f. security plan has been developed
g. updates and patches are applied in timely manner
3.	Mandatory	CA Browser Forum 5		

		Check the security plan covers the following safeguards:
a. administrative,
b. organizational,
c. technical, and
d. physical
4. Verify formal change management procedures have been developed
</p>				
3.1.1.16	<p>Hypervisors, operating system, database, and network device patches and updates shall be applied in a timely manner when deemed necessary based on a risk assessment and follow formal change management procedures
</p>	<p>1. Obtain copy of annual Risk Assessment plan
2. Check the following:
a. Threats are identified and documented as part of risk assessment
b. Standard operating procedures are present for combating threats.
c. controls are in place to prevent misuse, alteration and destruction of sensitive information
d. adequate cyber security tools are implemented by the CA such as DLP, Web Gateway, Email Gateway, Proxy Servers, and Firewalls, SSL/TLS, IDS/IPS, SAST, DAST, etc.
e. a vulnerability assessment by the above mentioned tools are carried out at a pre decided interval. Report any scheduled VA left out.
f. security plan has been developed
g. updates and patches are applied in timely manner
3. Check the security plan covers the following safeguards:
a. administrative,
b. organizational,
c. technical, and
d. physical
4. Verify formal change management procedures have been developed
</p>	Mandatory	WebTrust 3.6.18		
Training						
3.1.1.17	<p>The CA shall ensure all personnel performing duties with respect to operation of a CA,ESP, CSP shall receive comprehensive training covering the following:
1. CA/ESP/CSP/RA security principles and mechanisms
2. All PKI software versions in use on the CA system
3. All PKI duties they are expected to perform
4. Disaster recovery and business continuity procedures
</p>	<p>1. Obtain the training plan and material for CA employees
2. Check the following:
a. All relevant topics are covered in the training material
b. Records of training are maintained by CA (e.g. Attendance sheet)
c. Refresher training is conducted
d. Training is given personnel in case of implementation of every new tool by the CA
e. Personnel are trained with the update business continuity policy and procedures at regular intervals
f. Training requirements are reviewed at least once a year
3. Obtain list of personnel entrusted with validation specialist duties
4. Check the following
a. Validation specialist are trained to maintain required skill level
b. All Validation Specialists have passed the examination provided by the CA
5. Obtain list of personnel	Mandatory	X.509 Policy 5.3.3, IT CA Rules SCHEDULE-III.15		

		responsible for trusted roles 6. Check if the changes made in CA, ESP, CSP operations were communicated with individuals responsible for trusted roles 7. Verify only trusted personals are performing verification at all levels				
3.1.1.18	Refresher training must be conducted as and when required, and the Certifying Authority must review these requirements at least once a year. Records of all trainings shall be maintained and reviewed periodically	1. Obtain the training plan and material for CA employees 2. Check the following: a. All relevant topics are covered in the training material b. Records of training are maintained by CA (e.g. Attendance sheet) c. Refresher training is conducted d. Training is given personnel in case of implementation of every new tool by the CA e. Personnel are trained with the update business continuity policy and procedures at regular intervals f. Training requirements are reviewed at least once a year 3. Obtain list of personnel entrusted with validation specialist duties 4. Check the following a. Validation specialist are trained to maintain required skill level b. All Validation Specialists have passed the examination provided by the CA 5. Obtain list of personnel responsible for trusted roles 6. Check if the changes made in CA, ESP, CSP operations were communicated with individuals responsible for trusted roles 7. Verify only trusted personals are performing verification at all levels	Mandatory	IT CA Rules SCHEDULE III 16 CA Browser Forum 5.3.3		
3.1.1.19	CA shall ensure personnel entrusted with Validation Specialist duties maintain a skill level that enables them to perform such duties satisfactorily	1. Obtain the training plan and material for CA employees 2. Check the following: a. All relevant topics are covered in the training material b. Records of training are maintained by CA (e.g. Attendance sheet) c. Refresher training is conducted d. Training is given personnel in case of implementation of every new tool by the CA e. Personnel are trained with the update business continuity policy and procedures at regular intervals f. Training requirements are reviewed at least once a year 3. Obtain list of personnel entrusted with validation specialist duties 4. Check the following a. Validation specialist are trained to maintain required skill level b. All Validation Specialists have passed the examination provided by the	Mandatory	CA Browser Forum 5.3.3		

		CA 5. Obtain list of personnel responsible for trusted roles 6. Check if the changes made in CA, ESP, CSP operations were communicated with individuals responsible for trusted roles 7. Verify only trusted personals are performing verification at all levels				
3.1.1.20	All Validation Specialists shall pass an examination provided by the CA on the information verification requirements	1. Obtain the training plan and material for CA employees 2. Check the following: a. All relevant topics are covered in the training material b. Records of training are maintained by CA (e.g. Attendance sheet) c. Refresher training is conducted d. Training is given personnel in case of implementation of every new tool by the CA e. Personnel are trained with the update business continuity policy and procedures at regular intervals f. Training requirements are reviewed at least once a year 3. Obtain list of personnel entrusted with validation specialist duties 4. Check the following a. Validation specialist are trained to maintain required skill level b. All Validation Specialists have passed the examination provided by the CA 5. Obtain list of personnel responsible for trusted roles 6. Check if the changes made in CA, ESP, CSP operations were communicated with individuals responsible for trusted roles 7. Verify only trusted personals are performing verification at all levels	Mandatory	CA Browser Forum 5.3.3		
3.1.1.21	All individuals responsible for trusted roles shall be made aware of any significant changes in the CA, ESP CSP, or RA operations, as applicable.	1. Obtain the training plan and material for CA employees 2. Check the following: a. All relevant topics are covered in the training material b. Records of training are maintained by CA (e.g. Attendance sheet) c. Refresher training is conducted d. Training is given personnel in case of implementation of every new tool by the CA e. Personnel are trained with the update business continuity policy and procedures at regular intervals f. Training requirements are reviewed at least once a year 3. Obtain list of personnel entrusted with validation specialist duties 4. Check the following a. Validation specialist are trained to maintain required skill level b. All Validation Specialists have passed the	Mandatory	X.509 Policy 5.3.4 CA Browser Forum 5.3.4		

		examination provided by the CA 5. Obtain list of personnel responsible for trusted roles 6. Check if the changes made in CA, ESP, CSP operations were communicated with individuals responsible for trusted roles 7. Verify only trusted personals are performing verification at all levels				
--	--	--	--	--	--	--

3.1.2. Information Classification

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Information Classification							
3.1.2.1	Documented processes shall be created for classification, declassification, labeling, storage, access, destruction and reproduction of classified data.	1. Obtain copy of the process for handling classified data 2. Check the following a. procedure exists for classifying data based on its sensitivity for the CA b. procedures exist for destruction, access and reproduction of data c. Information is labeled in accordance with CA's information classification documented procedures	Mandatory	IT CA Rules 19.1, WebTrust			
3.1.2.2	CA shall ensure information labeling and handling are performed in accordance with the CA's information classification documented procedures basis following categories: - Confidential - Restricted - Internal - Unclassified - Top Secret - Secret - Confidentiality - Restricted - Unclassified	1. Obtain copy of the process for handling classified data 2. Check the following a. procedure exists for classifying data based on its sensitivity for the CA b. procedures exist for destruction, access and reproduction of data c. Information is labeled in accordance with CA's information classification documented procedures	Mandatory	WebTrust 3.2.4			

3.1.3. Information Management

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
System Administration							
3.1.3.1	The CA shall designate a trained "System Administrators" who will ensure that the protective security measures of the system are functional and who will maintain the security posture of CA's organization	1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		do basis containing proper business justification and also only after the authorization is documented.
9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done.
10. Conduct walkthrough to verify the PKI servers are monitored continuously
11. Obtain list of users who have access to the system
12. Verify only authorized personnel have access and no generic user is enabled or active
</p>					
3.1.3.2	<p>The System Administrator may have a designated System Security Administrator who will assume security
responsibilities and provide physical, logical and procedural safeguards for information
</p>	<p>1. Obtain the name of system administrator appointed by the CA
2. Check the following:
a. Roles and responsibilities of system administrator have been documented.
b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented
c. proper training was provided to Security Administrator
d. Security Administrator is solely responsible for changes done to information
3. Obtain the password management policy
4. Validate the process implemented in case of forgetting password or changeover to another person
5. Verify if the instance of	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		usage of administrator's passwords is documented securely
6. Obtain the Active Directory of CA employees
7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access
8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented.
9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done.
10. Conduct walkthrough to verify the PKI servers are monitored continuously
11. Obtain list of users who have access to the system
12. Verify only authorized personnel have access and no generic user is enabled or active
</p>					
3.1.3.3	<p>CA shall ensure System Security Administrator is properly trained before assigning the system security responsibilities
</p>	<p>1. Obtain the name of system administrator appointed by the CA
2. Check the following:
a. Roles and responsibilities of system administrator have been documented.
b. a designated System Security Administrator has	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		been appointed for System Administrator with roles and responsibilities documented
c. proper training was provided to Security Administrator
d. Security Administrator is solely responsible for changes done to information
3. Obtain the password management policy
4. Validate the process implemented in case of forgetting password or changeover to another person
5. Verify if the instance of usage of administrator's passwords is documented securely
6. Obtain the Active Directory of CA employees
7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access
8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented.
9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done.
10. Conduct walkthrough to verify the PKI servers are monitored continuously
11. Obtain list of users who have access to					
--	--	---	--	--	--	--	--

		the system 12. Verify only authorized personnel have access and no generic user is enabled or active </p>					
3.1.3.4	System Administrator shall solely be responsible for creating, classifying, and retrieving, modifying, deleting or archiving information. 	<p>1. Obtain the name of system administrator appointed by the CA 2. Check the following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented.
9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done.
10. Conduct walkthrough to verify the PKI servers are monitored continuously
11. Obtain list of users who have access to the system
12. Verify only authorized personnel have access and no generic user is enabled or active
</p>					
3.1.3.5	<p>The system administration's password and operation of trusted services must not be written down (in paper or electronic form) or shared with anyone.
</p>	<p>1. Obtain the name of system administrator appointed by the CA
2. Check the following:
a. Roles and responsibilities of system administrator have been documented.
b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented
c. proper training was provided to Security Administrator
d. Security Administrator is solely responsible for changes done to information
3. Obtain the password management policy
4. Validate the process implemented in case of forgetting password or	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		changeover to another person
5. Verify if the instance of usage of administrator's passwords is documented securely
6. Obtain the Active Directory of CA employees
7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access
8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented.
9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done.
10. Conduct walkthrough to verify the PKI servers are monitored continuously
11. Obtain list of users who have access to the system
12. Verify only authorized personnel have access and no generic user is enabled or active
</p>					
3.1.3.6	<p>A system for password management should be put in place to cover the eventualities such as forgotten password or changeover to another person in case of System Administrator (or System Security Administrator) leaving the organization. Every instance of usage of administrator's	<p>1. Obtain the name of system administrator appointed by the CA
2. Check the following:
a. Roles and responsibilities of system administrator have been documented.
b. a	Mandatory	IT CA Rules SCHEDULE-II 5.1			

	passwords must be documented.	designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented. c. proper training was provided to Security Administrator. d. Security Administrator is solely responsible for changes done to information. 3. Obtain the password management policy. 4. Validate the process implemented in case of forgetting password or changeover to another person. 5. Verify if the instance of usage of administrator's passwords is documented securely. 6. Obtain the Active Directory of CA employees. 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access. 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored					
--	--------------------------------------	--	--	--	--	--	--

		continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active </p>					
3.1.3.7	<p>The System Administrator shall promptly disable access to a user's account if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access. Reactivation of the user's account must be authorized in writing by the System Administrator (Digitally signed E-mail may be acceptable)
</p>	<p>1. Obtain the name of system administrator appointed by the CA
2. Check the following:
a. Roles and responsibilities of system administrator have been documented.
b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented
c. proper training was provided to Security Administrator
d. Security Administrator is solely responsible for changes done to information
3. Obtain the password management policy
4. Validate the process implemented in case of forgetting password or changeover to another person
5. Verify if the instance of usage of administrator's passwords is documented securely
6. Obtain the Active Directory of CA employees
7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		requiring system access
8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented.
9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done.
10. Conduct walkthrough to verify the PKI servers are monitored continuously
11. Obtain list of users who have access to the system
12. Verify only authorized personnel have access and no generic user is enabled or active
</p>					
3.1.3.8	<p>The System Administrator must take steps to safeguards classified information as prescribed by its owner.
</p>	<p>1. Obtain the name of system administrator appointed by the CA
2. Check the following:
a. Roles and responsibilities of system administrator have been documented.
b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented
c. proper training was provided to Security Administrator
d. Security Administrator is solely responsible for changes done to information
3. Obtain the password management policy
4. Validate the process	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		implemented in case of forgetting password or changeover to another person
5. Verify if the instance of usage of administrator's passwords is documented securely
6. Obtain the Active Directory of CA employees
7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access
8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented.
9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done.
10. Conduct walkthrough to verify the PKI servers are monitored continuously
11. Obtain list of users who have access to the system
12. Verify only authorized personnel have access and no generic user is enabled or active
</p>					
3.1.3.9	<p>The System Administrator must authorize privileged access to users only on a need-to-know and need-to-do basis and also only after the authorization is documented.
</p>	<p>1. Obtain the name of system administrator appointed by the CA
2. Check the following:
a. Roles and responsibilities of	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		system administrator have been documented.
b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented
c. proper training was provided to Security Administrator
d. Security Administrator is solely responsible for changes done to information
3. Obtain the password management policy
4. Validate the process implemented in case of forgetting password or changeover to another person
5. Verify if the instance of usage of administrator's passwords is documented securely
6. Obtain the Active Directory of CA employees
7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access
8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented.
9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done.
10.					
--	--	---	--	--	--	--	--

		Conduct walkthrough to verify the PKI servers are monitored continuously
11. Obtain list of users who have access to the system
12. Verify only authorized personnel have access and no generic user is enabled or active
</p>					
3.1.3.10	<p>All security violations must be recorded, investigated, and periodic status reports compiled for review by the
management
</p>	<p>1. Obtain the name of system administrator appointed by the CA
2. Check the following:
a. Roles and responsibilities of system administrator have been documented.
b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented
c. proper training was provided to Security Administrator
d. Security Administrator is solely responsible for changes done to information
3. Obtain the password management policy
4. Validate the process implemented in case of forgetting password or changeover to another person
5. Verify if the instance of usage of administrator's passwords is documented securely
6. Obtain the Active Directory of CA employees
7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		left the Data Centre, changed assignments, or is no longer requiring system access
8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented.
9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done.
10. Conduct walkthrough to verify the PKI servers are monitored continuously
11. Obtain list of users who have access to the system
12. Verify only authorized personnel have access and no generic user is enabled or active
</p>					
3.1.3.11	<p>The System Administrator together with the system support staff, shall conduct a regular analysis of problems reported to and identify any weaknesses in protection of the information
</p>	<p>1. Obtain the name of system administrator appointed by the CA
2. Check the following:
a. Roles and responsibilities of system administrator have been documented.
b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented
c. proper training was provided to Security Administrator
d. Security Administrator is solely responsible for changes done to information
3. Obtain the password	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done. 10. Conduct walkthrough to verify the PKI servers are monitored continuously 11. Obtain list of users who have access to the system 12. Verify only authorized personnel have access and no generic user is enabled or active					
3.1.3.12	The System Administrator shall ensure that the data, file and Public Key Infrastructure (PKI) servers are not left	1. Obtain the name of system administrator appointed by the CA 2. Check the	Mandatory	IT CA Rules SCHEDULE-II 5.1			

	unmonitored while these systems are powered on	following: a. Roles and responsibilities of system administrator have been documented. b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented c. proper training was provided to Security Administrator d. Security Administrator is solely responsible for changes done to information 3. Obtain the password management policy 4. Validate the process implemented in case of forgetting password or changeover to another person 5. Verify if the instance of usage of administrator's passwords is documented securely 6. Obtain the Active Directory of CA employees 7. For sample user accounts verify the System Administrator promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access 8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented. 9. Obtain sample of security violations and verify the process followed for recording,					
--	---	--	--	--	--	--	--

		investigating and management reviews done.
10. Conduct walkthrough to verify the PKI servers are monitored continuously
11. Obtain list of users who have access to the system
12. Verify only authorized personnel have access and no generic user is enabled or active
</p>					
3.1.3.13	<p>The System Administrator should ensure that no generic user is enabled or active on the system
</p>	<p>1. Obtain the name of system administrator appointed by the CA
2. Check the following:
a. Roles and responsibilities of system administrator have been documented.
b. a designated System Security Administrator has been appointed for System Administrator with roles and responsibilities documented
c. proper training was provided to Security Administrator
d. Security Administrator is solely responsible for changes done to information
3. Obtain the password management policy
4. Validate the process implemented in case of forgetting password or changeover to another person
5. Verify if the instance of usage of administrator's passwords is documented securely
6. Obtain the Active Directory of CA employees
7. For sample user accounts verify the System Administrator	Mandatory	IT CA Rules SCHEDULE-II 5.1			

		promptly disabled access if the user is identified as having left the Data Centre, changed assignments, or is no longer requiring system access
8. Validate privileged access is given to users only on a need-to-know and need-to-do basis containing proper business justification and also only after the authorization is documented.
9. Obtain sample of security violations and verify the process followed for recording, investigating and management reviews done.
10. Conduct walkthrough to verify the PKI servers are monitored continuously
11. Obtain list of users who have access to the system
12. Verify only authorized personnel have access and no generic user is enabled or active
</p>					
--	--	--	--	--	--	--	--

Sensitive Information Control

3.1.3.14	<p>Electronic communication systems, such as router, switches, network device and computers, used for transmission of sensitive information should be equipped or installed with suitable security software and if necessary with an encryptor or encryption software. The appropriate procedure in this regard shall be documented
</p>	<p>1. Obtain documented procedure to ensure safety of communication systems
2. Obtain list of communication systems (i.e. router, switches & computers) used for transmission of sensitive information
3. Verify security implementation in devices is done as per the procedure
</p>	Mandatory	IT CA Rules SCHEDULE-II 5.2			
3.1.3.15	<p>The Certifying Authority shall manage its functions in accordance with the levels of integrity and security	<p>1. Verify the CA manages its functions in accordance with the levels of integrity	Mandatory	IT Regulations 3			

	approved by the Controller from time to time	and security approved by the Controller from time to time. 2. Validate the CA discloses information on the assurance levels of certificates that it issues and the limitations of its liabilities to each of its subscribers and relying parties					
3.1.3.16	The Certifying Authority shall disclose information on the assurance levels of the certificates that it issues and the limitations of its liabilities to each of its subscribers and relying parties	1. Verify the CA manages its functions in accordance with the levels of integrity and security approved by the Controller from time to time. 2. Validate the CA discloses information on the assurance levels of certificates that it issues and the limitations of its liabilities to each of its subscribers and relying parties	Mandatory	IT Regulations 3			
Sensitive Information Security							
3.1.3.17	Highly sensitive information assets shall be stored on secure removable media and should be in an encrypted format to avoid compromise by unauthorized persons.	1. Refer the Process for handling classified data 2. Verify Highly sensitive information assets is stored on secure removable media and is in encrypted format 3. Verify highly sensitive information is classified in accordance as per Control No. 3.1.2.1 4. Validate access control mechanism exist for cases where multiple people have access to sensitive information and data 5. Conduct a walkthrough to verify removable electronic storage media is removed from the computer and properly secured at	Mandatory	T CA Rules SCHEDULE-II 5.3			

		the end of the work session or workday </p>					
3.1.3.18	Highly sensitive information shall be classified in accordance as per Control No. 3.1.2.1 	1. Refer the Process for handling classified data 2. Verify Highly sensitive information assets is stored on secure removable media and is in encrypted format 3. Verify highly sensitive information is classified in accordance as per Control No. 3.1.2.1 4. Validate access control mechanism exist for cases where multiple people have access to sensitive information and data 5. Conduct a walkthrough to verify removable electronic storage media is removed from the computer and properly secured at the end of the work session or workday 	Mandatory	IT CA Rules SCHEDULE-II 5.3			
3.1.3.19	Sensitive information and data, which are stored on the fixed disk of a computer shared by more than one person, must be protected by access control software (e.g., password). Security packages must be installed which partition or provide authorization to segregated directories/files. 	<p>1. Refer the Process for handling classified data 2. Verify Highly sensitive information assets is stored on secure removable media and is in encrypted format 3. Verify highly sensitive information is classified in accordance as per Control No. 3.1.2.1 4. Validate access control mechanism exist for cases where multiple people have access to sensitive information and data 5. Conduct a walkthrough to verify removable electronic storage media is removed from the computer and	Mandatory	IT CA Rules SCHEDULE-II 5.3			

		properly secured at the end of the work session or workday </p>					
3.1.3.20	Removable electronic storage media must be removed from the computer and properly secured at the end of the work session or workday. 	1. Refer the Process for handling classified data 2. Verify Highly sensitive information assets is stored on secure removable media and is in encrypted format 3. Verify highly sensitive information is classified in accordance as per Control No. 3.1.2.1 4. Validate access control mechanism exist for cases where multiple people have access to sensitive information and data 5. Conduct a walkthrough to verify removable electronic storage media is removed from the computer and properly secured at the end of the work session or workday 	Mandatory	IT CA Rules SCHEDULE-II 5.3			
Prevention of Computer Misuse							
3.1.3.21	The computer system shall be configured with minimum of the required accounts and network services. 	<p>1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach	Mandatory	X.509 Policy 6.5.1			

		reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident					
3.1.3.22	Prevention, detection, and deterrence measures shall be implemented to safeguard the security of computers and computer information from misuse. The measures taken shall be properly documented and reviewed regularly.	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident	Mandatory	IT CA Rules SCHEDULE-II 5.5			
3.1.3.23	CA shall ensure adequate information is provided to all persons, including management, systems developers and programmers, end-users, and third party users warning them against misuse of computers.	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the following: a. Implementation of	Mandatory	IT CA Rules SCHEDULE-II 5.5			

		measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident					
3.1.3.24	Effective measures including reporting of suspected breach, investigation and remedial measures shall be established	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident	Mandatory	IT CA Rules SCHEDULE-II 5.5			
3.1.3.25	All incidents related to breaches shall be reported to the System Administrator or System Security Administrator for appropriate action to prevent future occurrence. These will be responsible for investigation and follow up action	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and	Mandatory	IT CA Rules SCHEDULE-II 5.5			

		computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident </p>					
3.1.3.26	Procedure shall be set-up to establish the nature of any alleged abuse and determine the subsequent action required to be taken to prevent its future occurrence 	1. For sample computer system verify configuration is done with minimum of the required accounts and network services. 2. Validate systems are not working on default settings 3. Obtain documented measures for safeguard the security of computers and computer information from misuse 4. Check the following: a. Implementation of measures for safeguarding computers and information from misuse b. Breach reporting process and remedial measures taken c. All incidents are reported to System Administrator d. Procedure to prevent future occurrence of an incident 	Mandatory	IT CA Rules SCHEDULE-II 5.5			

3.1.4. Physical and Operational security

Control No.	Control	Audit Checks	Control Type	References
Site Location & Design				
3.1.4.1	<p>The location and	<p>1. Verify the CA facility housing CA and CSP equipment is	Mandatory	X.509 Polio

	construction of the facility housing CA and Certificate Status Provider (CSP) equipment shall be consistent with facilities used to house high value, sensitive information. The site shall not be in locations that are prone to natural or man-made disasters, like flood, fire, chemical contamination and explosions	consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden		5.1.1, IT C. Rules SCHEDULE III 3.1
3.1.4.2	Construction shall be done in compliance with all applicable building and safety regulations as laid down by the relevant Government agencies with use of fire resistant material and non-toxic chemicals.	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden	Mandatory	IT CA Rule SCHEDULE II 4.1.3
3.1.4.3	CA Shall ensure all external walls shall be constructed of brick or reinforced concrete of sufficient thickness to resist forcible attack. Ground level windows shall be fortified with sturdy mild steel grills or impact-resistant laminated security glass. All internal walls must be from the floor to the ceiling and must be tamper-evident	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper- evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information	Mandatory	IT CA Rule SCHEDULE II 4.1.5

		7. Verify measures CA has implemented to keep the location of DSC system hidden		
3.1.4.4	Air-conditioning system, power supply system and uninterrupted power supply unit with proper backup shall be installed depending upon the nature of operation. All ducting holes of the air-conditioning system must be designed so as to prevent intrusion of any kind.	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper-evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden	Mandatory	IT CA Rule SCHEDULE II 4.1.6
3.1.4.5	Media library, electrical and mechanical control rooms shall be housed in separate isolated areas, with access granted only to specific, named individuals on a need basis	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper-evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden	Mandatory	IT CA Rule SCHEDULE II 4.1.8
3.1.4.6	Any facility that supports mission-critical and sensitive applications must be located and designed for reparability, relocation and reconfiguration. The ability to relocate, reconstitute and reconfigure these applications must be tested as part of the business continuity/disaster recovery plan.	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper-evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated	Mandatory	IT CA Rule SCHEDULE II 4.1.9

		areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden		
3.1.4.7	All removable media and papers containing sensitive or plain text information shall be listed, documented and stored in a container properly identified in the CA Facility	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper-evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden	Mandatory	IT CA Rule SCHEDULE III 3.3
3.1.4.8	CA shall ensure exact location of Digital Signature Certification System shall not be publicly identified	1. Verify the CA facility housing CA and CSP equipment is consistent with facilities used to house high value, sensitive information 2. Validate the site is located in secure area immune from natural or man-made disasters 3. Verify applicable building and safety regulations were complied to during construction 4. Conduct walkthrough to check the following: a. External walls are constructed of brick or reinforced concrete of sufficient thickness b. Ground level windows are fortified with sturdy mild steel grills c. All internal walls are tamper-evident d. Air-conditioning system, power supply system and uninterrupted power supply unit are installed e. Proper backup is present in case of power outage f. Ducting holes are designed to prevent intrusion g. Media library, electrical and mechanical control rooms are housed in separate isolated areas h. Access to these areas is granted to specific, named individuals on a need basis i. Media library, electrical and mechanical control rooms is housed in separate isolated areas 5. For mission-critical and sensitive applications verify the facility is located and designed for reparability, relocation and reconfiguration 6. Verify containers are used for storing movable media and papers containing sensitive or plain text information 7. Verify measures CA has implemented to keep the location of DSC system hidden	Mandatory	IT CA Rule SCHEDULE III 3.3
Fire Protection				
3.1.4.9	No combustible materials shall be stored within hundred meters of the operational site	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an	Mandatory	IT CA Rule SCHEDULE II 4.2

		emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis </p>		
3.1.4.10	Automatic fire detection, fire suppression systems and audible alarms as prescribed by the Fire Brigade or any other agency of the Central or State Government shall be installed at the operational site 	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis 	Mandatory	IT CA Rule SCHEDULE II 4.2
3.1.4.11	Fire extinguishers shall be installed at the operational site and their locations clearly marked with appropriate signs 	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis 	Mandatory	IT CA Rule SCHEDULE II 4.2
3.1.4.12	Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems should be carried out. 	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis 	Mandatory	IT CA Rule SCHEDULE II 4.3
3.1.4.13	There shall be no eating, drinking or smoking in the operational site 	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly pasted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis 	Mandatory	IT CA Rule SCHEDULE II 4.2

3.1.4.14	The work areas shall be kept clean at all times.	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly posted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis	Mandatory	IT CA Rule SCHEDULE II 4.2
3.1.4.15	Procedures for the safe evacuation of personnel in an emergency shall be visibly posted/displayed at prominent places at the operational site	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly posted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis	Mandatory	IT CA Rule SCHEDULE II 4.2
3.1.4.16	Periodic training and fire drills shall be conducted	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly posted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis	Mandatory	IT CA Rule SCHEDULE II 4.2
3.1.4.17	Fire doors exist on security perimeters around CA operational facilities and are alarmed and conform to local fire regulations.	1. Conduct walkthrough to check the following: a. No combustible materials is stored within hundred meters of the operational site b. Automatic fire detection, fire suppression systems and audible alarms are installed at the operational site c. Fire extinguishers are installed at operational site d. Location of fire extinguishers is clearly marked with appropriate signs e. Periodic testing, inspection and maintenance of the fire equipment and fire suppression systems are carried out f. Eating, drinking and smoking are prohibited in the operational site g. Operational site is clean h. Procedures for the safe evacuation of personnel in an emergency are visibly posted/displayed at prominent places i. Fire doors exist on security perimeters 2. Obtain schedule of safety trainings and fire drills and verify they are conducted on periodic basis	Mandatory	WebTrust 3.4.6
Physical Access				
3.1.4.18	Responsibilities round the clock, seven days a	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct	Mandatory	IT CA Rule SCHEDULE

	week, three hundred sixty five days a year for physical security of the systems used for operation and also actual physical layout at the site of operation shall be defined and assigned to named individuals	walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system		II 4.4, CA Browser Forum 5.1.
3.1.4.19	All Certifying Authority personnel must have their identity and authorization verified before they are included in the access list for physical access to the Certifying Authority's system. All personnel are required to wear visible identification. Employees are encouraged to challenge anyone not wearing visible identification	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system	Mandatory	WebTrust 3.4.9 IT CA Rules SCHEDULE
3.1.4.20	Dual control over the inventory and issue of access cards/keys during normal business hours to the Data Centre shall be in place.	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by	Mandatory	IT CA Rules SCHEDULE II 4.4

		checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system		
3.1.4.21	Entrance to the main building where the Certifying Authority's facilities such as Data Centre, PKI Server and Network devices are housed and entrance to each security zone shall be video recorded round the clock. The recording must be carefully scrutinized and maintained for at least one year	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system	Mandatory	IT CA Rule SCHEDULE III 3.5
3.1.4.22	Biometric physical access security systems shall be installed to control and audit access to the operational site	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security	Mandatory	IT CA Rule SCHEDULE II 4.4

		system works on the basis of digital signature certification system </p><p> </p>		
3.1.4.23	Unauthorized intrusion shall be manually or electronically monitored at all times at the CAs Site 	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system 	Mandatory	IT CA Rule SCHEDULE II 3.4.6
3.1.4.24	Physical access to CA facilities and equipment should be limited to authorized individuals, protected through restricted security perimeters, and shall be operated under multiple person (at least dual custody) control. Personnel authorized for limited physical access shall not be allowed to gain unauthorized access to restricted area within operational site 	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system 	Mandatory	WebTrust 4.8.3, IT C. Rules SCHEDULE II 4.4
3.1.4.25	A manned reception area or other means to control physical access should be present at the CA operations site 	<p>1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system</p><p>b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the	Mandatory	WebTrust 3.4.3

		recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system		
3.1.4.26	Unescorted access to Certifying Authority's server shall be limited to those personnel identified on an access list	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system	Mandatory	IT CA Rule SCHEDULE III 3.3
3.1.4.27	Access security system shall be installed to control and audit details of personnel using the Digital Signature Certification System.	1. Obtain copy of the responsibilities assigned for physical security and verify individuals have been assigned for the same 2. Conduct walkthrough to check the following a. All CA personnel have identity and authorization verified before they are included in the access list to CAs system b. All personnel wear visible identification c. Entrance to the main building and entrance to each security zone is video recorded round the clock. Verify on sample basis for last one year for any random date of each year d. Check the recording is carefully scrutinized and maintained for at least one year by verifying logs for a sample dates in the past year e. Biometric physical access security systems are installed and functioning in the operational site f. Unauthorized intrusion is manually or electronically monitored at all times at the CAs Site. Verify by checking the register/list maintained for same g. Physical access to CA facilities and equipment is limited to authorized individuals, protected through restricted security perimeters, and is operated under multiple person (at least dual custody) control. Verify by checking the access list / and checking the name of the personnel for dual custody. Physically see also, how the two personnel are involved in	Mandatory	IT CA Rule SCHEDULE III 3.6

		the operation h. A manned reception area is present at operational site i. Unescorted access to server is limited to those personnel identified on an access list. Verify by checking list of personnel allowed j. Access security system is installed to control and audit details of personnel using the DSC System. k. Access security system works on the basis of digital signature certification system		
3.1.4.28	An inventory of access cards shall be maintained by the CA and periodically reviewed	1. Verify the CA maintains and inventory of access cards and reviews it periodically 2. Obtain the up-to-date list of personnel who possess cards/keys 3. Verify the list is updated regularly and archived for a period of three years 4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed. 5. Conduct a walkthrough to check the following: a. Any personnel not on access list is escorted at all times within the operational site b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made. c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for logging. d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed. e. Access rights to all security zones are laid out. Verify by checking the access list for various security zones f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same 6. Collect site access log and verify all entries are recorded and inspected periodically	Mandatory	IT CA Rule SCHEDULE III 3.7
3.1.4.29	An up-to-date list of personnel who possess the cards/keys shall be regularly maintained and archived for a period of three years. Loss of access cards/keys shall be reported immediately to the Security Administrator; who shall take appropriate actions to prevent unauthorized access.	1. Verify the CA maintains and inventory of access cards and reviews it periodically 2. Obtain the up-to-date list of personnel who possess cards/keys 3. Verify the list is updated regularly and archived for a period of three years 4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed. 5. Conduct a walkthrough to check the following: a. Any personnel not on access list is escorted at all times within the operational site b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made. c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for logging. d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed. e. Access rights to all security zones are laid out. Verify by checking the access list for various security zones f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same 6. Collect site access log and verify all entries are recorded and inspected periodically	Mandatory	IT CA Rule SCHEDULE III 3.8
3.1.4.30	Any personnel not on the access list shall be properly escorted and supervised at all times within the operational site premises. All individuals, other than operations staff, shall sign in and sign out of the operational site and shall be accompanied by operations staff.	1. Verify the CA maintains and inventory of access cards and reviews it periodically 2. Obtain the up-to-date list of personnel who possess cards/keys 3. Verify the list is updated regularly and archived for a period of three years 4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed. 5. Conduct a walkthrough to check the following: a. Any personnel not on access list is escorted at all times within the operational site b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made. c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for	Mandatory	IT CA Rule IT CA Rule SCHEDULE III 3.9, SCHEDULE II 4.4

		logging.
d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed.
e. Access rights to all security zones are laid out. Verify by checking the access list for various security zones
f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same
6. Collect site access log and verify all entries are recorded and inspected periodically
</p>		
3.1.4.31	<p>A site access log shall be maintained at the Certifying Authority's operational site and inspected periodically. All personnel entering and leaving CA operational facilities shall be logged (i.e., an audit trail of all access is securely maintained).
</p>	<p>1. Verify the CA maintains and inventory of access cards and reviews it periodically
2. Obtain the up-to-date list of personnel who possess cards/keys
3. Verify the list is updated regularly and archived for a period of three years
4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed.
5. Conduct a walkthrough to check the following:
a. Any personnel not on access list is escorted at all times within the operational site
b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made. </p><p>c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for logging.
d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed.
e. Access rights to all security zones are laid out. Verify by checking the access list for various security zones
f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same
6. Collect site access log and verify all entries are recorded and inspected periodically
</p>	Mandatory	WebTrust 3.4.11, IT CA Rules SCHEDULE III 3.3
3.1.4.32	<p>A multi-tiered access mechanism must be installed at the Certifying Authority's operational site. The facility should have clearly laid out security zones within its facility with well-defined access rights to each security zone.
</p>	<p>1. Verify the CA maintains and inventory of access cards and reviews it periodically
2. Obtain the up-to-date list of personnel who possess cards/keys
3. Verify the list is updated regularly and archived for a period of three years
4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed.
5. Conduct a walkthrough to check the following:
a. Any personnel not on access list is escorted at all times within the operational site
b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made. </p><p>c. All personnel entering and leaving CA operational facilities are logged. Verify by checking the physical register or electronic media used for logging.
d. CA operational facility has security zones laid out within the facility. Verify the documented proof for zoning performed.
e. Access rights to all security zones are laid out. Verify by checking the access list for various security zones
f. Security zones are separate from the other by floor to ceiling concrete reinforced walls. Conduct physical walkthrough of the zones to ascertain the same
6. Collect site access log and verify all entries are recorded and inspected periodically
</p>	Mandatory	IT CA Rules SCHEDULE III 3.4
3.1.4.33	<p>Each security zone must be separated from the other by floor to ceiling concrete reinforced walls.
</p>	<p>1. Verify the CA maintains and inventory of access cards and reviews it periodically
2. Obtain the up-to-date list of personnel who possess cards/keys
3. Verify the list is updated regularly and archived for a period of three years
4. Validate the process followed in case of loss of access cards, check list of cases where cards were lost and verify if the process was followed.
5. Conduct a walkthrough to check the following:
a. Any personnel not on access list is escorted at all times within the operational site
b. All individuals, other than operations staff, sign in and sign out of the operational site and are accompanied by operations staff. Verify by checking register/log where entries have been made. </p><p>c. All personnel entering and leaving CA operational facilities are logged.	Mandatory	IT CA Rules SCHEDULE III 3.4

		be done in the presence of the auditor. </p>		
3.1.4.40	Computer System or PKI Server performing the Digital Signature Certification functions shall be dedicated to those functions and should not be used for any other purposes. 	1. Conduct walkthrough to check the following: a. Intrusion detection systems are used to monitor and record physical access to the DSC system during and after office hours b. Computer System or PKI Server performing the DSC functions are dedicated to those functions and should not be used for any other purposes c. Emergency exits are tested periodically. Validate by checking proper functioning of emergency exits. d. Unauthorized access to areas storing hardware is prohibited. Verify by checking the access list for areas storing the hardware. e. Two person physical access control are present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates. Practical demonstration of the two person physical access should be done in the presence of the auditor. 	Mandatory	IT CA Rule SCHEDULE III 3.11
3.1.4.41	Emergency exits shall be tested periodically to ensure that the access security systems are operational 	1. Conduct walkthrough to check the following: a. Intrusion detection systems are used to monitor and record physical access to the DSC system during and after office hours b. Computer System or PKI Server performing the DSC functions are dedicated to those functions and should not be used for any other purposes c. Emergency exits are tested periodically. Validate by checking proper functioning of emergency exits. d. Unauthorized access to areas storing hardware is prohibited. Verify by checking the access list for areas storing the hardware. e. Two person physical access control are present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates. Practical demonstration of the two person physical access should be done in the presence of the auditor. 	Mandatory	IT CA Rule SCHEDULE II 4.4
3.1.4.42	Unauthorized access to areas storing hardware shall be prohibited 	1. Conduct walkthrough to check the following: a. Intrusion detection systems are used to monitor and record physical access to the DSC system during and after office hours b. Computer System or PKI Server performing the DSC functions are dedicated to those functions and should not be used for any other purposes c. Emergency exits are tested periodically. Validate by checking proper functioning of emergency exits. d. Unauthorized access to areas storing hardware is prohibited. Verify by checking the access list for areas storing the hardware. e. Two person physical access control are present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates. Practical demonstration of the two person physical access should be done in the presence of the auditor. 	Mandatory	X.509 Policy 5.1.2.1
3.1.4.43	Two person physical access control shall be present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates. 	1. Conduct walkthrough to check the following: a. Intrusion detection systems are used to monitor and record physical access to the DSC system during and after office hours b. Computer System or PKI Server performing the DSC functions are dedicated to those functions and should not be used for any other purposes c. Emergency exits are tested periodically. Validate by checking proper functioning of emergency exits. d. Unauthorized access to areas storing hardware is prohibited. Verify by checking the access list for areas storing the hardware. e. Two person physical access control are present at both the cryptographic module and computer system for CAs issuing Class 1, Class 2 and Class 3 certificates. Practical demonstration of the two person physical access should be done in the presence of the auditor. 	Mandatory	X.509 Policy 5.1.2.
3.1.4.44	<p>Removable cryptographic modules shall be deactivated prior to storage. When not in use, removable cryptographic modules, activation	1. Verify removable cryptographic modules are deactivated before storage 2. Validate activation information used to access or enable cryptographic modules is placed in secure containers. 3. Check the mechanism used to store activation data 	Mandatory	X.509 Policy 5.1.2.1

	information used to access or enable cryptographic modules shall be placed in secure containers. Activation data shall either be memorized, or recorded and stored in a manner commensurate with the security afforded the cryptographic module, and shall not be stored with the cryptographic module.			
3.1.4.45	The Certifying Authority must ensure that no single individual may gain access to the Digital Signature Certificate server and the computer server maintaining all information associated with generation, issue and management of Digital Signature Certificate and private keys of the Certifying Authority. Minimum two individuals, preferably using a split-knowledge technique, such as twin passwords, must perform any operation associated with generation, issue and management of Digital Signature Certificate and application of private key of the Certifying Authority.	1. Verify the process of security check to be conducted if the facility housing the CA and CSP equipment is left unattended 2. Validate it covers the requirements mentioned in control description 3. Check the list of persons responsible for doing the security checks mentioned in control - 3.1.4.45 4. Verify if a group of people are assigned the security check responsibility a log identifying the person performing a check at each instance is maintained 5. Check if the facility is not continuously attended, the last person to depart initials a sign-out sheet that indicates the date and time, and asserts that all necessary physical protection mechanisms are in place and activated	Mandatory	IT CA Rule SCHEDULE III 12
Inventory Management				
3.1.4.46	Inventory control processes and procedures shall be documented and implemented to manage the origination, arrival, condition, departure and destination of each device.	1. Obtain copy of Inventory control processes and procedures and check the following: a. Policy and procedure are implemented to manage the origination, arrival, condition, departure and destination of each device. b. Details of all media are inventoried c. An independent physical inventory check of all media is conducted at least every six months. Verify by checking latest report of physical inventory check d. An up-to-date inventory list of all documentation is maintained. Verify by checking previous versions of inventory list to validate periodicity of update e. All equipment related to CA Operations are inventoried. Verify by conducting a random check on sample basis for the infrastructure and check its entry in to inventory	Mandatory	WebTrust 4.8.3
3.1.4.47	Details of all media shall be inventoried. An independent physical inventory check of all media shall be conducted at least every six months.	1. Obtain copy of Inventory control processes and procedures and check the following: a. Policy and procedure are implemented to manage the origination, arrival, condition, departure and destination of each device. b. Details of all media are inventoried c. An independent physical inventory check of all media is conducted at least every six months. Verify by checking latest report of physical inventory check d. An up-to-date inventory list of all documentation is maintained. Verify by checking previous versions of inventory list to validate periodicity of update e. All equipment related to CA Operations are inventoried. Verify by conducting a random check on sample basis for the infrastructure and check its entry in to inventory	Mandatory	IT CA Rule SCHEDULE II 8.3

3.1.4.48	An up-to-date inventory list of all documentation shall be maintained to ensure control and accountability.	1. Obtain copy of Inventory control processes and procedures and check the following: a. Policy and procedure are implemented to manage the origination, arrival, condition, departure and destination of each device. b. Details of all media are inventoried c. An independent physical inventory check of all media is conducted at least every six months. Verify by checking latest report of physical inventory check d. An up-to-date inventory list of all documentation is maintained. Verify by checking previous versions of inventory list to validate periodicity of update e. All equipment related to CA Operations are inventoried. Verify by conducting a random check on sample basis for the infrastructure and check its entry in to inventory	Mandatory	IT CA Rule SCHEDULE II 16
3.1.4.49	All equipment related to CA Operations shall be inventoried	1. Obtain copy of Inventory control processes and procedures and check the following: a. Policy and procedure are implemented to manage the origination, arrival, condition, departure and destination of each device. b. Details of all media are inventoried c. An independent physical inventory check of all media is conducted at least every six months. Verify by checking latest report of physical inventory check d. An up-to-date inventory list of all documentation is maintained. Verify by checking previous versions of inventory list to validate periodicity of update e. All equipment related to CA Operations are inventoried. Verify by conducting a random check on sample basis for the infrastructure and check its entry in to inventory	Mandatory	WebTrust 3.4.16
Media Storage				
3.1.4.50	All sensitive information stored in any media shall bear or be assigned an appropriate security classification.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.	Mandatory	IT CA Rule SCHEDULE II 5.2
3.1.4.51	Media library, electrical and mechanical control rooms shall be housed in separate isolated areas, with access granted only to	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named	Mandatory	IT CA Rule SCHEDULE II 4.1.8

	specific, named individuals on a need basis. The area must be fire resistant and free of toxic chemicals	individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and backup data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.		
3.1.4.52	Storage media (i.e. floppy diskettes, magnetic tapes, portable hard disks, optical disks, etc.) containing sensitive information shall be secured according to their classification	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and backup data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.	Mandatory	IT CA Rule SCHEDULE II 5.2
3.1.4.53	Responsibilities for media library management and protection shall be clearly defined and assigned	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d.	Mandatory	IT CA Rule SCHEDULE II 8.3

		Such area is fire resistant and free of toxic chemicals.
e. Storage media containing sensitive information is secured according to their classification
f. Responsibilities for media library management and protection are clearly defined and assigned
g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel)
h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored
i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location.
j. Media management system has been implemented by providing sample of the process followed.
k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis.
l. All media have external volume identification
m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed
n. Media retention procedure is established and approved by management
o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained.
p. Procedure are present for secure transfer and disposal of media
q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection
r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.
</p></p></p></p>		
3.1.4.54	<p>Access to the media library (both on-site and off-site) shall be restricted to the authorized persons only. A list of personnel authorized to enter the library shall be maintained
</p>	<p>1. Obtain Media Management policy and verify the following:
a. All sensitive information stored in any media is assigned an appropriate security classification
b. Media library, electrical and mechanical control rooms are housed in separate isolated areas
c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list
d. Such area is fire resistant and free of toxic chemicals.
e. Storage media containing sensitive information is secured according to their classification
f. Responsibilities for media library management and protection are clearly defined and assigned
g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel)
h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored
i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location.
j. Media management system has been implemented by providing sample of the process followed.
k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis.
l. All media have external volume identification
m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed
n. Media retention procedure is established and approved by management
o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained.
p. Procedure are present for secure transfer and disposal of media
q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection
r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.
</p></p></p></p>	Mandatory	IT CA Rule SCHEDULE II 8.3
3.1.4.55	<p>Media containing sensitive and back up data must be stored at three different physical locations in the country, which can be reached in few hours. Media that contains audit, archive,	<p>1. Obtain Media Management policy and verify the following:
a. All sensitive information stored in any media is assigned an appropriate security classification
b. Media library, electrical and mechanical control rooms are housed in separate isolated areas
c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list
d. Such area is fire resistant and free of toxic chemicals.
e. Storage	Mandatory	X.509 Policy IT CA Rule

	or backup information shall be duplicated and stored in a	media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and backup data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.		
3.1.4.56	Media containing sensitive and back up data must be stored at three different physical locations in the country, which can be reached in few hours. Media that contains audit, archive, or backup information shall be duplicated and stored in a location separate from the CA location.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and backup data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.	Mandatory	X.509 Policy IT CA Rule
3.1.4.57	A media management system shall be in place to account for all media stored on-site and off-site	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their	Mandatory	IT CA Rule SCHEDULE II 8.3

		classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and backup data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.		
3.1.4.58	All incoming/outgoing media transfers shall be authorized by management and users.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and backup data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.	Mandatory	IT CA Rule SCHEDULE II 8.3
3.1.4.59	All media shall have external volume identification. Internal labels shall be fixed, where available	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and	Mandatory	IT CA Rule SCHEDULE II 8.3

		protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and backup data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.		
3.1.4.60	Procedures shall be in place to ensure that only authorized addition/removal of media from the library is allowed.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and backup data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.	Mandatory	IT CA Rule SCHEDULE II 8.3
3.1.4.61	Media retention periods shall be established and approved by management in accordance with legal regulatory and user requirements.	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media	Mandatory	IT CA Rule SCHEDULE II 8.3

		library is restricted to the authorized persons only (verify by checking list of authorized personnel)
h. Media containing sensitive and backup data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored
i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location.
j. Media management system has been implemented by providing sample of the process followed.
k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis.
l. All media have external volume identification
m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed
n. Media retention procedure is established and approved by management
o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained.
p. Procedure are present for secure transfer and disposal of media
q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection
r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.
</p></p></p></p>		
3.1.4.62	<p>Proper records of all movements of computer tapes/disks between on-site and off-site media library must be
maintained.
</p>	<p>1. Obtain Media Management policy and verify the following:
a. All sensitive information stored in any media is assigned an appropriate security classification
b. Media library, electrical and mechanical control rooms are housed in separate isolated areas
c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list
d. Such area is fire resistant and free of toxic chemicals.
e. Storage media containing sensitive information is secured according to their classification
f. Responsibilities for media library management and protection are clearly defined and assigned
g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel)
h. Media containing sensitive and backup data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored
i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location.
j. Media management system has been implemented by providing sample of the process followed.
k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis.
l. All media have external volume identification
m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed
n. Media retention procedure is established and approved by management
o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained.
p. Procedure are present for secure transfer and disposal of media
q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection
r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.
</p></p></p></p>	Mandatory	IT CA Rule SCHEDULE II 8.4
3.1.4.63	<p>There shall be procedures to ensure the authorized and secure transfer to media to/from external parties and the off-site location including a means to authenticate the receipt shall be in place.
</p>	<p>1. Obtain Media Management policy and verify the following:
a. All sensitive information stored in any media is assigned an appropriate security classification
b. Media library, electrical and mechanical control rooms are housed in separate isolated areas
c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list
d. Such area is fire resistant and free of toxic chemicals.
e. Storage media containing sensitive information is secured according to their classification
f. Responsibilities for media library management and protection are clearly defined and assigned
g. Access to the media library is restricted to the authorized persons only (verify by checking	Mandatory	IT CA Rule SCHEDULE II 8.4

		list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal. </p><p> </p>		
3.1.4.64	Computer media that are being transported to off-site data backup locations should be stored in locked carrying cases that provide magnetic field protection and protection from impact while loading and unloading and during transportation 	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal. 	Mandatory	IT CA Rule SCHEDULE II 8.4
3.1.4.65	All items of equipment containing storage media (fixed and removable disks) shall be checked to ensure that they do not contain sensitive data prior to their disposal. 	<p>1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and back	Mandatory	WebTrust 3.4.21

		up data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.		
3.1.4.66	Procedures shall be in place to ensure the secure disposal of sensitive information assets on all corrupted/damaged or affected media both internal (e.g. hard disk/optical disk) and external (e.g. diskette, disk drive, tapes etc.) to the system	1. Obtain Media Management policy and verify the following: a. All sensitive information stored in any media is assigned an appropriate security classification b. Media library, electrical and mechanical control rooms are housed in separate isolated areas c. Access to these areas is given only to specific, named individuals on a need basis. Verify by checking the access list d. Such area is fire resistant and free of toxic chemicals. e. Storage media containing sensitive information is secured according to their classification f. Responsibilities for media library management and protection are clearly defined and assigned g. Access to the media library is restricted to the authorized persons only (verify by checking list of authorized personnel) h. Media containing sensitive and backup data is stored at three different physical locations in the country. Verify by identifying the three different physical locations where backup is stored i. Media that containing audit, archive, or backup information is duplicated and stored in a location separate from the CA location. j. Media management system has been implemented by providing sample of the process followed. k. All incoming/outgoing media transfers are authorized by management and users. Verify by checking on sample basis. l. All media have external volume identification m. Procedures are in place to ensure that only authorized addition/removal of media from the library is allowed n. Media retention procedure is established and approved by management o. Records of all movements of computer tapes/disks between on-site and off-site media library are maintained. p. Procedure are present for secure transfer and disposal of media q. Computer media that are being transported to off-site data backup locations are stored in locked carrying cases that provide magnetic field protection r. All items of equipment containing storage media are checked to ensure that they do not contain sensitive data prior to their disposal.	Mandatory	IT CA Rule SCHEDULE II 5.2
Power and Air Conditioning				
3.1.4.67	Air-conditioning system and power supply system unit shall be installed by the CA	1. Conduct walkthrough of CA facility and check the following: a. existence of Air conditioning and power supply system b. backup power is present to automatically lockout input, finish any pending actions, and record the state of the equipment before lack of power or air conditioning causes a shutdown	Mandatory	IT CA Rule SCHEDULE II 4.1
3.1.4.68	CAs shall have backup power sufficient to automatically lockout input, finish any pending actions, and record the state of the	1. Conduct walkthrough of CA facility and check the following: a. existence of Air conditioning and power supply system b. backup power is present to automatically lockout input, finish any pending actions, and record the state of the equipment before lack of power or air conditioning causes a shutdown	Mandatory	X.509 Policy 5.1.3

	equipment before lack of power or air conditioning causes a shutdown			
Waste Disposal				
3.1.4.69	Procedures shall be designed and implemented for disposing off sensitive waste material.	1. Verify procedure is present and implemented for disposing off the sensitive waste material 2. Validate all media used for storage of information pertaining to all functions	Mandatory	X.509 Policy 5.1.7, IT CA Rules SCHEDULE III 5
3.1.4.70	All media used for storage of information pertaining to all functions associated with generation, production, issue and management of Digital Signature Certificate shall be scrutinized before being destroyed or released for disposal	associated of DSC is scrutinized before being destroyed or released for disposal. Verify by checking on sample basis, media was disposed off based on defined procedure	Mandatory	IT CA Rules SCHEDULE III 5
Data Backup and Off-site Retention				
3.1.4.71	A Certifying Authority must ensure that facility used for off- site backup shall be within the country and shall have the same level of security as the primary Certifying Authority site	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up	Mandatory	WebTrust, CA Rules SCHEDULE III 6
3.1.4.72	Back-up procedures shall be documented, scheduled and monitored.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m.	Mandatory	IT CA Rules SCHEDULE II 9

		information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up p></p><p> </p>		
3.1.4.73	Full system backups of the CAs, sufficient to recover from system failure, shall be made on a periodic schedule 	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up 	Mandatory	X.509 Policy 5.1.8
3.1.4.74	Backups shall be performed and stored off-site not less than once every 7 days. At least one full backup copy shall be stored at an offsite location (at a location separate from the CA equipment). Only the latest full backup need be retained. 	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up 	Mandatory	X.509 Policy 5.1.8
3.1.4.75	One set of the original disks for all operating system and application software must be maintained to ensure that a valid, virus-free backup exists and is available for use at any time 	<p>1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is	Mandatory	IT CA Rule SCHEDULE II 9

		maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up		
3.1.4.76	Backups of the system, application and data shall be performed on a regular basis. Backups should also be made for application under development and data conversion efforts.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up	Mandatory	IT CA Rule SCHEDULE II 9
3.1.4.77	Data backup is required for all systems including personal computers, servers and distributed systems and databases.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up	Mandatory	IT CA Rule SCHEDULE II 9
3.1.4.78	Critical system data and	1. Conduct walkthrough of the CA backup site and check the	Mandatory	IT CA Rule

	file server software shall have full backups taken weekly.	following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up		SCHEDULE II 9
3.1.4.79	The Certifying Authority should verify the integrity of the backups at least once every six months	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up	Mandatory	IT CA Rule SCHEDULE II 9
3.1.4.80	The backups shall be kept in an area physically separate from the server. If critical system data on the LAN represents unique versions of the information assets, then the information backups should be rotated on a periodic basis to an off-site storage location.	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are	Mandatory	IT CA Rule SCHEDULE II 9

		completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up </p><p> </p>		
3.1.4.81	Critical system data and file server software must have incremental backups taken daily. 	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up 	Mandatory	IT CA Rule SCHEDULE II 9
3.1.4.82	Systems that are completely static may not require periodic backup, but shall be backed up after changes or updates in the information 	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up 	Mandatory	IT CA Rule SCHEDULE II 9
3.1.4.83	Each LAN/system should have a primary and backup operator to ensure continuity of business operations. 	<p>1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data	Mandatory	IT CA Rule SCHEDULE II 9

		backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up		
3.1.4.84	The security requirements of backup copies shall be consistent with the controls for the information backed up	1. Conduct walkthrough of the CA backup site and check the following: a. facility used for off-site backup is within the country and has the same level of security as the primary CA site b. backup procedures are documented and implemented c. Full system backups are made on periodic schedule d. Backups are performed and stored off-site not less than once every 7 days e. At least one full backup copy shall be stored at an offsite location f. One set of the original disks for all operating system and application software is maintained g. Backups of the system, application and data is performed on a regular basis h. Backups for application under development and data conversion efforts is also made i. Data backup is performed j. Critical system data and file server software have full backups taken weekly k. Documented proof of verifications of the integrity of backups every six months l. backups are kept in an area physically separate from the server m. information backups are rotated on a periodic basis to an off-site storage location n. Critical system data and file server software have incremental backups taken daily o. Systems that are completely static are backed up after changes or update in information p. Each LAN/system has a primary and backup operator to ensure continuity of business operations q. Security requirements of backup copies are consistent with control for information backed up	Mandatory	WebTrust 4.2.4
Environmental Protection				
3.1.4.85	Water detectors shall be installed under the raised floors throughout the operational site and shall be connected to audible alarms	1. Conduct walkthrough of the CA facility and check the following: a. Water detectors are installed under the raised floors throughout the operational site and are connected to audible alarms b. temperature and humidity condition in the operational site is monitored and controlled periodically c. periodic inspection, testing and maintenance of equipment is scheduled. Verify by checking previous reports on a sample basis based on frequency d. personnel at operational site is trained to monitor and control various devices	Mandatory	IT CA Rule SCHEDULE II 4.3
3.1.4.86	The temperature and humidity condition in the operational site shall be monitored and controlled periodically	1. Conduct walkthrough of the CA facility and check the following: a. Water detectors are installed under the raised floors throughout the operational site and are connected to audible alarms b. temperature and humidity condition in the operational site is monitored and controlled periodically c. periodic inspection, testing and maintenance of equipment is scheduled. Verify by checking previous reports on a sample basis based on frequency d. personnel at operational site is trained to monitor and control various devices	Mandatory	IT CA Rule SCHEDULE II 4.3
3.1.4.87	Periodic inspection, testing and maintenance of the equipment and systems shall be scheduled.	1. Conduct walkthrough of the CA facility and check the following: a. Water detectors are installed under the raised floors throughout the operational site and are connected to audible alarms b. temperature and humidity condition in the operational site is monitored and controlled periodically c. periodic inspection,	Mandatory	T CA Rule SCHEDULE II 4.3

		testing and maintenance of equipment is scheduled. Verify by checking previous reports on a sample basis based on frequency d. personnel at operational site is trained to monitor and control various devices		
3.1.4.88	Personnel at the operational site shall be trained to monitor and control the various equipment and devices installed at the operational site for the purpose of fire and environment protection	1. Conduct walkthrough of the CA facility and check the following: a. Water detectors are installed under the raised floors throughout the operational site and are connected to audible alarms b. temperature and humidity condition in the operational site is monitored and controlled periodically c. periodic inspection, testing and maintenance of equipment is scheduled. Verify by checking previous reports on a sample basis based on frequency d. personnel at operational site is trained to monitor and control various devices	Mandatory	IT CA Rule SCHEDULE II 4
Third Party Access				
3.1.4.89	Access to the computer systems by other Organizations shall be subjected to a similar level of security protection and controls as in stated in Information Technology security guidelines under IT CA Rules	1. Verify access to computer systems by other organizations is subjected to a similar level of security protection and controls as stated in IT CA Rules 2. Validate in case Data Centre uses external service/facility provider for any of their operations, all related risks are evaluated before onboarding the outsourced vendor 3. Verify on sample basis the external service or facility provider has signed non-disclosure agreements with the management of the Data Centre/operational site 4. Check the external service/facility provider provides an equivalent level of security controls as required by Information Technology Security Guidelines	Mandatory	IT CA Rule SCHEDULE II 5.4
3.1.4.90	In case the Data Centre uses the facilities of external service/facility provider (outsourcer) for any of their operations, the use of external service/facility providers (e.g. outsourcer) shall be evaluated in light of the possible security exposures and risks involved and all such agreements shall be approved by the information asset owner. The external service or facility provider shall also sign non-disclosure agreements with the management of the Data Centre/operational site.	1. Verify access to computer systems by other organizations is subjected to a similar level of security protection and controls as stated in IT CA Rules 2. Validate in case Data Centre uses external service/facility provider for any of their operations, all related risks are evaluated before onboarding the outsourced vendor 3. Verify on sample basis the external service or facility provider has signed non-disclosure agreements with the management of the Data Centre/operational site 4. Check the external service/facility provider provides an equivalent level of security controls as required by Information Technology Security Guidelines	Mandatory	IT CA Rule SCHEDULE II 5.4
3.1.4.91	The external service/facility provider (e.g. outsourcer) shall provide an equivalent level of security controls as required by Information Technology Security Guidelines	1. Verify access to computer systems by other organizations is subjected to a similar level of security protection and controls as stated in IT CA Rules 2. Validate in case Data Centre uses external service/facility provider for any of their operations, all related risks are evaluated before onboarding the outsourced vendor 3. Verify on sample basis the external service or facility provider has signed non-disclosure agreements with the management of the Data Centre/operational site 4. Check the external service/facility provider provides an equivalent level of security controls as required by Information Technology Security Guidelines	Mandatory	IT CA Rule SCHEDULE II 5.4

3.1.5. Personnel Security

Control	Control	Audit Checks	Control	References	Compliance	Document	Remarks
---------	---------	--------------	---------	------------	------------	----------	---------

No.			Type				
Personnel Security							
3.1.5.1	The Certifying Authority must ensure that all personnel performing duties with respect to its operation must: • be appointed in writing; • be bound by contract or statute to the terms and conditions of the position they are to fill; • have received comprehensive training with respect to the duties they are to perform; • be bound by statute or contract not to disclose sensitive Certifying Authority's security related information or subscriber information; • not be assigned duties that may cause a conflict of interest with their Certifying Authority's duties; • be aware and trained in the relevant aspects of the Information Technology Security Policy and Security Guidelines framed for carrying out Certifying Authority's operation	1. For sample CA personnel, perform the following checks: a. personnel received an offer letter with roles and responsibilities appointed in writing. Verify on sample basis for personnel b. personnel is bound by contract or statute to the terms and conditions of the position they are to fill. Verify by checking the contract c. personnel has received comprehensive training via sessions organized specifically for the job. Check training logs d. personnel is bound by statute or contract not to disclose sensitive CA's security related information or subscriber information and has signed NDA for same. e. personnel is not assigned duties that may cause a conflict of interest with their CA's duties f. personnel is aware and trained in the relevant aspects of the Information Technology Security Policy and Security Guidelines	Mandatory	IT CA Rules SCHEDULE III 14			
3.1.5.2	A Certifying Authority must make available to his personnel the Digital Signature Certificate policies it supports, its	1. Validate CA has made available to his personnel the DSC policies, CPS, IT security guideline,	Mandatory	IT CA Rules SCHEDULE III 17			

	Certification Practice Statement, Information Technology Security Policy and any specific statutes, policies or contracts relevant to their position
</p>	Information Technology Security Policy and any specific statutes, policies or contracts relevant to their position
2. Verify the CA provides reasonable assurance that personnel and employment practices enhance and
support the trustworthiness of the CA's operations and receive regular security/PKI based trainings
</p>					
3.1.5.3	<p>The CA shall provide reasonable assurance that personnel and employment practices enhance and support the trustworthiness of the CA's operations
</p>	<p>1. Validate CA has made available to his personnel the DSC policies, CPS, IT security guideline, Information Technology Security Policy and any specific statutes, policies or contracts relevant to their position
2. Verify the CA provides reasonable assurance that personnel and employment practices enhance and
support the trustworthiness of the CA's operations and receive regular security/PKI based trainings
</p>	Mandatory	WebTrust 3.3			
3.1.5.4	<p>Prior to the engagement of any person whether as an employee, agent, or an independent contractor of the CA, the CA shall verify perform a background check. The scope of the background check shall include the following areas covering the past five years:
• Employment;
• Education (Regardless of the date of award, the highest educational degree shall be verified);
• Place of	<p>1.Check the documented procedure detailing the background check criteria for an employee or an independent contractor of the CA
2. Verify that the scope of background check contains the details covered in control description
</p>	Mandatory	WebTrust 3.3.7, X.509 Policy 5.3.2			

	residence (3 years); • Law Enforcement; and • References The background shall be refreshed every three years						
3.1.5.5	The CA and CSP shall make available to its personnel this certificate policy, the applicable CPS, and any relevant statutes, policies or contracts	1. Verify the CA and CSP share all relevant statutes, policies or contracts with their personnel	Mandatory	X.509 Policy 5.3.7			
3.1.5.6	Personnel appointed to trusted roles (CA trusted roles) shall: • Have successfully completed an appropriate training program; • Have demonstrated the ability to perform their duties; • Be trustworthy; • Have no other duties that would interfere or conflict with their duties for the trusted role; • Have not been previously relieved of duties for reasons of negligence or nonperformance of duties; • Have not been denied a security clearance, or had a security clearance revoked for cause; • Have not been convicted of a felony offense; and • Be appointed in writing by an approving authority • Be bound by statute or contract not to disclose sensitive Certifying Authority's security related information or subscriber information;	1. Obtain the list of personnel having CA trusted roles 2. Verify for sample personnel, they adhere to the requirements mentioned in control description 3. Validate the personnel in Trusted Roles maintain skill levels consistent with the CA's training and performance programs	Mandatory	X.509 Policy 5.3.1			
3.1.5.7	All personnel in Trusted Roles shall maintain skill levels consistent with the CA's training and performance programs.	1. Obtain the list of personnel having CA trusted roles 2. Verify for sample personnel, they adhere to the requirements	Mandatory	CA Browser Forum 5.3.4			

		mentioned in control description 3. Validate the personnel in Trusted Roles maintain skill levels consistent with the CA's training and performance programs					
--	--	---	--	--	--	--	--

3.1.6. System integrity and security measures

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
User's Account Management							
3.1.6.1	Procedures for user account management shall be established to control access to application systems and data	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of	Mandatory	IT CA Rules SCHEDULE II 6.5			

		the conditions mentioned in control 3.1.6.32 are met </p>					
3.1.6.2	Users shall be authorized by the computer system owner to access the computer services 	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met 	Mandatory	IT CA Rules SCHEDULE II 6.5			
3.1.6.3	A written statement of access rights shall be given to all users. 	<p>1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account	Mandatory	IT CA Rules SCHEDULE II 6.5			

		management
b. Users are authorized by the computer system owner to access the computer services
c. written statement of access rights is given to all users
d. all users sign an undertaking to acknowledge that they understand the conditions of access
e. Access is only provided after authorization is complete
f. Formal record of all registered users of the computer services is maintained
g. Access rights of users who have been transferred, or left the organization are removed immediately
h. Periodic checks are carried out for redundant user accounts
i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met
</p>					
3.1.6.4	<p>All users shall be required to sign an undertaking to acknowledge that they understand the conditions of access
</p>	<p>1. For the User Account Management process, check the following on sample basis:
a. Procedures have been designed and implemented for user account management
b. Users are authorized by the computer system owner to access the computer services
c. written statement of access rights is given to all users
d. all users sign an undertaking to acknowledge that they understand the conditions of access
e. Access	Mandatory	IT CA Rules SCHEDULE II 6.5			

		is only provided after authorization is complete
f. Formal record of all registered users of the computer services is maintained
g. Access rights of users who have been transferred, or left the organization are removed immediately
h. Periodic checks are carried out for redundant user accounts
i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met
</p>					
3.1.6.5	<p>Where access to computer services is administered by service providers, access shall not be provided until authorization is completed. This shall include the acknowledgment of receipt of the accounts by the users
</p>	<p>1. For the User Account Management process, check the following on sample basis:
a. Procedures have been designed and implemented for user account management
b. Users are authorized by the computer system owner to access the computer services
c. written statement of access rights is given to all users
d. all users sign an undertaking to acknowledge that they understand the conditions of access
e. Access is only provided after authorization is complete
f. Formal record of all registered users of the computer services is maintained
g. Access rights of users who have been transferred, or left the organization are removed immediately
h. Periodic checks are	Mandatory	IT CA Rules SCHEDULE II 6.5			

		carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met </p>					
3.1.6.6	A formal record of all registered users of the computer services shall be maintained. 	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met 	Mandatory	IT CA Rules SCHEDULE II 6.5			
3.1.6.7	<p>Access rights of users who have been transferred, or left the organization shall be removed	<p>1. For the User Account Management process, check the following on sample	Mandatory	IT CA Rules SCHEDULE II 6.5			

	immediately </p>	basis:
a. Procedures have been designed and implemented for user account management
b. Users are authorized by the computer system owner to access the computer services
c. written statement of access rights is given to all users
d. all users sign an undertaking to acknowledge that they understand the conditions of access
e. Access is only provided after authorization is complete
f. Formal record of all registered users of the computer services is maintained
g. Access rights of users who have been transferred, or left the organization are removed immediately
h. Periodic checks are carried out for redundant user accounts
i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met
</p>					
3.1.6.8	<p>A periodic check shall be carried out for redundant user accounts and access rights that are no longer required. Redundant user accounts shall not be re-issued to another user
</p>	<p>1. For the User Account Management process, check the following on sample basis:
a. Procedures have been designed and implemented for user account management
b. Users are authorized by the computer system owner to access the computer services
c. written statement of access rights is given to all users
d. all users sign an	Mandatory	IT CA Rules SCHEDULE II 6.5			

		undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met					
3.1.6.9	User accounts shall be suspended under the following conditions	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been	Mandatory	IT CA Rules SCHEDULE II 6.5			

		transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met					
3.1.6.10	User accounts shall be suspended under the following conditions - When an individual is on extended leave or inactive use of over thirty days. In case of protected computer system, the limit of thirty days may be reduced to fifteen days by the System Administrator. - Immediately upon the termination of the services of an individual. - Suspended or inactive accounts shall be deleted after a two months period. In case of protected computer systems, the limit of two months may be reduced to one month.	1. For the User Account Management process, check the following on sample basis: a. Procedures have been designed and implemented for user account management b. Users are authorized by the computer system owner to access the computer services c. written statement of access rights is given to all users d. all users sign an undertaking to acknowledge that they understand the conditions of access e. Access is only provided after authorization is complete f. Formal record of all registered users of the computer services is maintained g. Access rights of users who have been transferred, or left the organization are removed immediately h. Periodic checks are carried out for redundant user accounts i. User accounts are suspended if any of the conditions mentioned in control 3.1.6.32 are met	Mandatory	IT CA Rules SCHEDULE II 6.5			

Use of Security Systems or Facilities							
3.1.6.11	Security controls shall be installed and maintained on each computer system or computer node to prevent unauthorized users from gaining entry to the information system and to prevent unauthorized access to data.	1. For sample computers, check the minimum baseline security controls are installed and maintained on each computer system 2. Validate system software or resource of the computer system is accessible after being authenticated by access control system	Mandatory	IT CA Rules SCHEDULE II 6.1			
3.1.6.12	Security controls shall be installed and maintained on each computer system or computer node to prevent unauthorized users from gaining entry to the information system and to prevent unauthorized access to data.	1. For sample computers, check the minimum baseline security controls are installed and maintained on each computer system 2. Validate system software or resource of the computer system is accessible after being authenticated by access control system	Mandatory	IT CA Rules SCHEDULE II 6.1			
3.1.6.13	Any system software or resource of the computer system should only be accessible after being authenticated by access control system	1. For sample computers, check the minimum baseline security controls are installed and maintained on each computer system 2. Validate system software or resource of the computer system is accessible after being authenticated by access control system	Mandatory	IT CA Rules SCHEDULE II 6.1			
System Access Control							
3.1.6.14	Access control software and system software security features shall be implemented to protect resources. Management approval is required to authorize issuance of user identification (ID)	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance	Mandatory	IT CA Rules SCHEDULE II 6.2, IT Regulations 3			

	and resource privileges.
Approved access and integrity controls such as intrusion detection, virus scanning, prevention of denial-of service attacks and physical security measures shall be followed by the Certifying Authority for all its systems that store and process the subscribers' information and certificates.
</p>	of user identification (ID) and resource privileges
b. Access control software and system software security features are implemented
c. Approved access and integrity controls are implemented
d. access control software or operating system of the computer system provides features to restrict access to the system and data resources
e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters.
f. A documented Access Control System manual is present
g. Each user is assigned a unique user ID
h. Sharing IDs is prohibited
i. Stored passwords are encrypted
j. Stored passwords are protected by access controls
k. Automatic time-out for terminal inactivity is implemented
l. Activities of all remote users are logged and monitored closely
m. facility to login as another user from one user's login is denied
n. startup and shutdown procedure of the security software is Automated
o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques</p><p>p. Only System Administrator is allowed to modify systemoperated					
--	---	---	--	--	--	--	--

		files </p>					
3.1.6.15	<p>The access control software or operating system of the computer system shall provide features to restrict access to the system and data resources. The use of common passwords such as "administrator" or "president" or "game" etc. to protect
</p>	<p>1. For the system access controls implemented in CA facility check on sample basis the following:
a. Management approval is required to authorize issuance of user identification (ID) and resource privileges
b. Access control software and system software security features are implemented
c. Approved access and integrity controls are implemented
d. access control software or operating system of the computer system provides features to restrict access to the system and data resources
e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters.
f. A documented Access Control System manual is present
g. Each user is assigned a unique user ID
h. Sharing IDs is prohibited
i. Stored passwords are encrypted
j. Stored passwords are protected by access controls
k. Automatic time-out for terminal inactivity is implemented
l. Activities of all remote users are logged and monitored closely
m. facility to login as another user from one user's login is denied
n. startup and shutdown procedure of the	Mandatory	IT CA Rules SCHEDULE II 6.2			

		security software is Automated
o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques</p><p>p. Only System Administrator is allowed to modify systemoperated files
</p>					
3.1.6.16	<p>The access control software or operating system of the computer system shall provide features to restrict access to the system and data resources. The use of common passwords such as "administrator" or "president" or "game" etc. to protect access to the system and data resources represent a security
exposure and shall be avoided. All passwords used must be
resistant to dictionary attacks.
</p>	<p>1. For the system access controls implemented in CA facility check on sample basis the following:
a. Management approval is required to authorize issuance of user identification (ID) and resource privileges
b. Access control software and system software security features are implemented
c. Approved access and integrity controls are implemented
d. access control software or operating system of the computer system provides features to restrict access to the system and data resources
e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters.
f. A documented Access Control System manual is present
g. Each user is assigned a unique user ID
h. Sharing IDs is prohibited
i. Stored passwords are encrypted
j. Stored passwords are protected by access controls
k. Automatic time-out for terminal inactivity is	Mandatory	IT CA Rules SCHEDULE II 6.2			

		implemented
l. Activities of all remote users are logged and monitored closely
m. facility to login as another user from one user's login is denied
n. startup and shutdown procedure of the security software is Automated
o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques</p><p>p. Only System Administrator is allowed to modify systemoperated files
</p>					
3.1.6.17	<p>An Access Control System manual documenting the access granted to different level of users shall be prepared to provide guidance to the System Administrator for grant of access.
</p>	<p>1. For the system access controls implemented in CA facility check on sample basis the following:
a. Management approval is required to authorize issuance of user identification (ID) and resource privileges
b. Access control software and system software security features are implemented
c. Approved access and integrity controls are implemented
d. access control software or operating system of the computer system provides features to restrict access to the system and data resources
e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters.
f. A documented Access Control System manual is present
g. Each user is assigned a	Mandatory	IT CA Rules SCHEDULE II 6.2			

		unique user ID
h. Sharing IDs is prohibited
i. Stored passwords are encrypted
j. Stored passwords are protected by access controls
k. Automatic time-out for terminal inactivity is implemented
l. Activities of all remote users are logged and monitored closely
m. facility to login as another user from one user's login is denied
n. startup and shutdown procedure of the security software is Automated
o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques</p><p>p. Only System Administrator is allowed to modify systemoperated files
</p>					
3.1.6.18	<p>Each user shall be assigned a unique user ID. Adequate user education shall be provided to help users in password choice and password protection. Sharing of user IDs shall not be allowed
</p>	<p>1. For the system access controls implemented in CA facility check on sample basis the following:
a. Management approval is required to authorize issuance of user identification (ID) and resource privileges
b. Access control software and system software security features are implemented
c. Approved access and integrity controls are implemented
d. access control software or operating system of the computer system provides features to restrict access to the system and data	Mandatory	IT CA Rules SCHEDULE II 6.2			

		resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files					
3.1.6.19	Stored passwords shall be encrypted using internationally proven encryption techniques to prevent unauthorized disclosure and modification.	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security	Mandatory	IT CA Rules SCHEDULE II 6.2			

		features are implemented
c. Approved access and integrity controls are implemented
d. access control software or operating system of the computer system provides features to restrict access to the system and data resources
e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters.
f. A documented Access Control System manual is present
g. Each user is assigned a unique user ID
h. Sharing IDs is prohibited
i. Stored passwords are encrypted
j. Stored passwords are protected by access controls
k. Automatic time-out for terminal inactivity is implemented
l. Activities of all remote users are logged and monitored closely
m. facility to login as another user from one user's login is denied
n. startup and shutdown procedure of the security software is Automated
o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques</p><p>p. Only System Administrator is allowed to modify systemoperated files
</p>					
3.1.6.20	<p>Stored passwords shall be protected by access controls from	<p>1. For the system access controls implemented in CA	Mandatory	IT CA Rules SCHEDULE II 6.2			

	unauthorized disclosure and modification
</p>	facility check on sample basis the following:
a. Management approval is required to authorize issuance of user identification (ID) and resource privileges
b. Access control software and system software security features are implemented
c. Approved access and integrity controls are implemented
d. access control software or operating system of the computer system provides features to restrict access to the system and data resources
e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters.
f. A documented Access Control System manual is present
g. Each user is assigned a unique user ID
h. Sharing IDs is prohibited
i. Stored passwords are encrypted
j. Stored passwords are protected by access controls
k. Automatic time-out for terminal inactivity is implemented
l. Activities of all remote users are logged and monitored closely
m. facility to login as another user from one user's login is denied
n. startup and shutdown procedure of the security software is Automated
o. Sensitive Operating System files are protected against all known attacks using					
--	---	--	--	--	--	--	--

		proven tools and techniques Only System Administrator is allowed to modify system operated files					
3.1.6.21	Automatic time-out for terminal inactivity should be implemented	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m.	Mandatory	IT CA Rules SCHEDULE II 6.2			

		facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify system operated files					
3.1.6.22	Where a second level access control is implemented through the application system, password controls similar to those implemented for the computer system shall be in place .	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance of user identification (ID) and resource privileges b. Access control software and system software security features are implemented c. Approved access and integrity controls are implemented d. access control software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j.	Mandatory	IT CA Rules SCHEDULE II 6.2			

		Stored passwords are protected by access controls
k. Automatic time-out for terminal inactivity is implemented
l. Activities of all remote users are logged and monitored closely
m. facility to login as another user from one user's login is denied
n. startup and shutdown procedure of the security software is Automated
o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques</p><p>p. Only System Administrator is allowed to modify systemoperated files
</p>					
3.1.6.23	<p>Activities of all remote users shall be logged and monitored closely
</p>	<p>1. For the system access controls implemented in CA facility check on sample basis the following:
a. Management approval is required to authorize issuance of user identification (ID) and resource privileges
b. Access control software and system software security features are implemented
c. Approved access and integrity controls are implemented
d. access control software or operating system of the computer system provides features to restrict access to the system and data resources
e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special	Mandatory	IT CA Rules SCHEDULE II 6.2			

		characters.
f. A documented Access Control System manual is present
g. Each user is assigned a unique user ID
h. Sharing IDs is prohibited
i. Stored passwords are encrypted
j. Stored passwords are protected by access controls
k. Automatic time-out for terminal inactivity is implemented
l. Activities of all remote users are logged and monitored closely
m. facility to login as another user from one user's login is denied
n. startup and shutdown procedure of the security software is Automated
o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques</p><p>p. Only System Administrator is allowed to modify systemoperated files
</p>					
3.1.6.24	<p>The facility to login as another user from one user's login shall be denied. However, the system should prohibit direct login as a trusted user (e.g. root in Unix, administrator in Windows NT or Windows 2000). This means that there must be a user account configured for the trusted administrator.
</p>	<p>1. For the system access controls implemented in CA facility check on sample basis the following:
a. Management approval is required to authorize issuance of user identification (ID) and resource privileges
b. Access control software and system software security features are implemented
c. Approved access and integrity controls are implemented
d. access control	Mandatory	IT CA Rules SCHEDULE II 6.2			

		software or operating system of the computer system provides features to restrict access to the system and data resources e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters. f. A documented Access Control System manual is present g. Each user is assigned a unique user ID h. Sharing IDs is prohibited i. Stored passwords are encrypted j. Stored passwords are protected by access controls k. Automatic time-out for terminal inactivity is implemented l. Activities of all remote users are logged and monitored closely m. facility to login as another user from one user's login is denied n. startup and shutdown procedure of the security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify system operated files					
3.1.6.25	The startup and shutdown procedure of the security software must be Automated	1. For the system access controls implemented in CA facility check on sample basis the following: a. Management approval is required to authorize issuance	Mandatory	IT CA Rules SCHEDULE II 6.2			

		of user identification (ID) and resource privileges
b. Access control software and system software security features are implemented
c. Approved access and integrity controls are implemented
d. access control software or operating system of the computer system provides features to restrict access to the system and data resources
e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters.
f. A documented Access Control System manual is present
g. Each user is assigned a unique user ID
h. Sharing IDs is prohibited
i. Stored passwords are encrypted
j. Stored passwords are protected by access controls
k. Automatic time-out for terminal inactivity is implemented
l. Activities of all remote users are logged and monitored closely
m. facility to login as another user from one user's login is denied
n. startup and shutdown procedure of the security software is Automated
o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques</p><p>p. Only System Administrator is allowed to modify systemoperated					
--	--	---	--	--	--	--	--

		files </p>					
3.1.6.26	Sensitive Operating System files, which are more prone to hackers must be protected against all known attacks using proven tools and techniques. That is to say no user will be able to modify them except with the permission of System Administrator.
</p>	1. For the system access controls implemented in CA facility check on sample basis the following:
a. Management approval is required to authorize issuance of user identification (ID) and resource privileges
b. Access control software and system software security features are implemented
c. Approved access and integrity controls are implemented
d. access control software or operating system of the computer system provides features to restrict access to the system and data resources
e. All passwords used are resistant to dictionary attacks and contain letters, numerals and special characters.
f. A documented Access Control System manual is present
g. Each user is assigned a unique user ID
h. Sharing IDs is prohibited
i. Stored passwords are encrypted
j. Stored passwords are protected by access controls
k. Automatic time-out for terminal inactivity is implemented
l. Activities of all remote users are logged and monitored closely
m. facility to login as another user from one user's login is denied
n. startup and shutdown procedure of the	Mandatory	IT CA Rules SCHEDULE II 6.2			

		security software is Automated o. Sensitive Operating System files are protected against all known attacks using proven tools and techniques p. Only System Administrator is allowed to modify systemoperated files					
Password Management							
3.1.6.27	Quality standards for password shall be enforced. The quality level shall be increased progressively. The following control features shall be implemented for passwords: • Minimum of eight • characters without leading or trailing blanks; • Shall be different from the existing password and the two previous ones; • Shall be changed at least once every ninety days; for sensitive system password shall be changed at least once every thirty days; and • Shall not be shared, displayed or printed. Shall have at least on number, one capital letter, one small case letter and one special character	1. Verify on sample basis the passwords used across CA systems comply with the requirements mentioned in control 2. Verify on sample basis the password retries is limited to maximum three attempts (two for sensitive for sensitive systems) 3. Check the user ID is revoked after the user exhausts permissible limit of password retries on sample basis 4. Validate the initial or reset passwords is changed by the user upon first use 5. Check the passwords are encrypted instorage to prevent unauthorized disclosure and protect them from dictionary attacks and all known password cracking algorithms.	Mandatory	IT CA Rules SCHEDULE II 6.3			
3.1.6.28	Password retries shall be limited to a maximum of three attempted logons after which the user ID shall then be revoked; for sensitive systems, the number of password retries should be limited to a maximum of two.	1. Verify on sample basis the passwords used across CA systems comply with the requirements mentioned in control 2. Verify on sample basis the password retries is limited to maximum three attempts (two for sensitive	Mandatory	IT CA Rules SCHEDULE II 6.3			

		for sensitive systems). 3. Check the user ID is revoked after the user exhausts permissible limit of password retries on sample basis. 4. Validate the initial or reset passwords is changed by the user upon first use. 5. Check the passwords are encrypted in storage to prevent unauthorized disclosure and protect them from dictionary attacks and all known password cracking algorithms.					
3.1.6.29	Initial or reset passwords must be changed by the user upon first use. Users shall follow defined policies and procedures in the selection and use of passwords.	1. Verify on sample basis the passwords used across CA systems comply with the requirements mentioned in control. 2. Verify on sample basis the password retries is limited to maximum three attempts (two for sensitive for sensitive systems). 3. Check the user ID is revoked after the user exhausts permissible limit of password retries on sample basis. 4. Validate the initial or reset passwords is changed by the user upon first use. 5. Check the passwords are encrypted in storage to prevent unauthorized disclosure and protect them from dictionary attacks and all known password cracking algorithms.	Mandatory	WebTrust 3.6.6, IT CA Rules SCHEDULE II 6.3			
3.1.6.30	Passwords shall always be encrypted in storage to prevent unauthorized disclosure and protect them from dictionary attacks and all	1. Verify on sample basis the passwords used across CA systems comply with the requirements	Mandatory	IT CA Rules SCHEDULE II 6.3			

	known password cracking algorithms. </p>	mentioned in control 2. Verify on sample basis the password retries is limited to maximum three attempts (two for sensitive for sensitive systems) 3. Check the user ID is revoked after the user exhausts permissible limit of password retries on sample basis 4. Validate the initial or reset passwords is changed by the user upon first use 5. Check the passwords are encrypted instorage to prevent unauthorized disclosure and protect them from dictionary attacks and all known password cracking algorithms. </p>					
Privileged User`s Management							
3.1.6.31	System privileges shall be granted to users only on a need-to- use basis. Login privileges for highly privileged accounts should be available only from Console and terminals situated within Console room. 	<p>1. For the privileged user management process, check the following on sample basis: a. System privileges are granted to users only on a need-to-use basis b. Login privileges for highly privileged accounts are available only from Console and terminals situated within Console room c. An audit trail of activities conducted by highly privileged users is maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator d. Privileged user is be allowed to log in to the computer system from remote terminal e.	Mandatory	IT CA Rules SCHEDULE II 6.4			

		Separate user IDs are allowed to the user for performing privileged and normal (non-privileged) activities f. user IDs for emergency use are recorded and approved. g. Passwords are reset after emergency use					
3.1.6.32	An audit trail of activities conducted by highly privileged users shall be maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator	1. For the privileged user management process, check the following on sample basis: a. System privileges are granted to users only on a need-to-use basis b. Login privileges for highly privileged accounts are available only from Console and terminals situated within Console room c. An audit trail of activities conducted by highly privileged users is maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator d. Privileged user is be allowed to log in to the computer system from remote terminal e. Separate user IDs are allowed to the user for performing privileged and normal (non-privileged) activities f. user IDs for emergency use are recorded and approved. g. Passwords are reset after emergency use	Mandatory	IT CA Rules SCHEDULE II 6.4			
3.1.6.33	Privileged user shall not be allowed to log in to the computer system from remote terminal.	1. For the privileged user management process, check the	Mandatory	IT CA Rules SCHEDULE II 6.4			

	The usage of the computer system by the privilege user shall be allowed during a certain time period.
</p>	following on sample basis:
a. System privileges are granted to users only on a need-to-use basis
b. Login privileges for highly privileged accounts are available only from Console and terminals situated within Console room
c. An audit trail of activities conducted by highly privileged users is maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator
d. Privileged user is be allowed to log in to the computer system from remote terminal
e. Separate user IDs are allowed to the user for performing privileged and normal (non-privileged) activities
f. user IDs for emergency use are recorded and approved.
g. Passwords are reset after emergency use
</p>					
3.1.6.34	<p>Separate user IDs shall be allowed to the user for performing privileged and normal (non-privileged) activities.
</p>	<p>1. For the privileged user management process, check the following on sample basis:
a. System privileges are granted to users only on a need-to-use basis
b. Login privileges for highly privileged accounts are available only from Console and terminals situated within Console room
c. An audit trail of activities conducted by highly privileged users is maintained for two years and reviewed	Mandatory	IT CA Rules SCHEDULE II 6.4			

		periodically at least every week by operator who is independent of System Administrator d. Privileged user is be allowed to log in to the computer system from remote terminal e. Separate user IDs are allowed to the user for performing privileged and normal (non-privileged) activities f. user IDs for emergency use are recorded and approved. g. Passwords are reset after emergency use					
3.1.6.35	The use of user IDs for emergency use shall be recorded and approved. The passwords shall be reset after use.	1. For the privileged user management process, check the following on sample basis: a. System privileges are granted to users only on a need-to-use basis b. Login privileges for highly privileged accounts are available only from Console and terminals situated within Console room c. An audit trail of activities conducted by highly privileged users is maintained for two years and reviewed periodically at least every week by operator who is independent of System Administrator d. Privileged user is be allowed to log in to the computer system from remote terminal e. Separate user IDs are allowed to the user for performing privileged and normal (non-privileged) activities f. user	Mandatory	T CA Rules SCHEDULE II 6.4			

		IDs for emergency use are recorded and approved. g. Passwords are reset after emergency use </p>					
Data and Resource Protection							
3.1.6.36	All information assets shall be assigned an "owner" responsible for the integrity of that data/resource. Custodians shall be assigned and shall be jointly responsible for information assets by providing computer controls to assist owners. 	1. Check the list of data assets and the corresponding owner/custodian for the same. 	Mandatory	IT CA Rules SCHEDULE II 6.6			
3.1.6.37	The operating system or security system of the computer system shall: • Define user authority and enforce access control to data within the computer system; • Be capable of specifying, for each named individual, a list of named data objects (e.g. file, Programme) or groups of named objects, and the type of access allowed. 	1. Verify the operating system or security system of the computer system define user authority and enforce access control to data within the computer system Check these are capable of specifying for each named individual, a list of named data objects (e.g. file, Programme) or groups of named objects, and the type of access allowed. 	Mandatory	IT CA Rules SCHEDULE II 6.6			
3.1.6.38	For networked or shared computer systems, system users shall be limited to a profile of data objects required to perform their needed tasks 	1. Verify for networked or shared computer systems, system users shall be limited to a profile of data objects required to perform their needed tasks 	Mandatory	IT CA Rules SCHEDULE II 6.6			
3.1.6.39	Application Programmer shall not be allowed to access the production system 	2. Validate that application programmer does not have access to the production system 	Mandatory	IT CA Rules SCHEDULE II 6.6			
3.1.6.40	<p>Procedures shall be implemented to ensure the secure storage or distribution of all outputs/reports, in	<p>1. For the jobs performed in the Data Centre check the following: a. procedures have	Mandatory	IT CA Rules SCHEDULE II 8.2			

	accordance with procedures defined by the owners for each system </p>	been established to ensure that all changes to the job schedules are appropriately approved
b. list of people who have been assigned authority to approve changes to job schedule
c. automated job scheduling is used
d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made.
e. Procedures are established to maintain logs of system activities
f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment
g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system
</p>					
Sensitive Systems Protection							
3.1.6.41	<p>Security tokens/smart cards/bio-metric technologies such as Iris recognition, finger print verification technologies etc. shall be used to complement the usage of passwords to access the computer system
</p>	<p>1. For sensitive system protection, check the following have been implemented:
a. Security tokens/smart cards/bio-metric technologies such as Iris recognition etc. are used to complement the usage of passwords to access the computer system
b. For	Mandatory	IT CA Rules SCHEDULE II 7			

		computer system processing sensitive data, identify the list of organizations which have access to sensitive data and check the access control measures implemented to establish its effectiveness c. Data in storage is encrypted					
3.1.6.42	For computer system processing sensitive data, access by other Organizations shall be prohibited or strictly controlled.	1. For sensitive system protection, check the following have been implemented: a. Security tokens/smart cards/bio-metric technologies such as Iris recognition etc. are used to complement the usage of passwords to access the computer system b. For computer system processing sensitive data, identify the list of organizations which have access to sensitive data and check the access control measures implemented to establish its effectiveness c. Data in storage is encrypted	Mandatory	IT CA Rules SCHEDULE II 7			
3.1.6.43	For sensitive data, encryption of data in storage shall be considered to protect its confidentiality and integrity.	1. For sensitive system protection, check the following have been implemented: a. Security tokens/smart cards/bio-metric technologies such as Iris recognition etc. are used to complement the usage of passwords to access the computer system b. For computer system processing sensitive data, identify the list of organizations which have access to	Mandatory	IT CA Rules SCHEDULE II 7			

		sensitive data and check the access control measures implemented to establish its effectiveness c. Data in storage is encrypted </p>					
Data Centre Operations Security							
3.1.6.44	<p>Procedures shall be established to ensure that all changes to the job schedules are appropriately approved. The authority to approve changes to job schedules shall be clearly assigned.
</p>	<p>1. For the jobs performed in the Data Centre check the following:
a. procedures have been established to ensure that all changes to the job schedules are appropriately approved
b. list of people who have been assigned authority to approve changes to job schedule
c. automated job scheduling is used
d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made.
e. Procedures are established to maintain logs of system activities
f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment
g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system
</p>	Mandatory	IT CA Rules SCHEDULE II 8.1			
3.1.6.45	<p>As far as possible, automated job	<p>1. For the jobs performed in the	Mandatory	IT CA Rules SCHEDULE			

	scheduling should be used. Manual job scheduling should require prior approval from the competent authority
</p>	Data Centre check the following:
a. procedures have been established to ensure that all changes to the job schedules are appropriately approved
b. list of people who have been assigned authority to approve changes to job schedule
c. automated job scheduling is used
d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made.
e. Procedures are established to maintain logs of system activities
f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment
g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system
</p>		II 8.1			
3.1.6.46	<p>Procedures shall be established to ensure that only authorized and correct job stream and parameter changes are made.
</p>	<p>1. For the jobs performed in the Data Centre check the following:
a. procedures have been established to ensure that all changes to the job schedules are appropriately approved
b. list of people who have been assigned authority to approve changes to job	Mandatory	IT CA Rules SCHEDULE II 8.2			

		schedule
c. automated job scheduling is used
d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made.
e. Procedures are established to maintain logs of system activities
f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment
g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system
</p>					
3.1.6.47	<p>Procedures shall be established to maintain logs of system activities. Such logs shall be reviewed by a competent independent party for indications of dubious activities. Appropriate retention periods shall be set for such logs.
</p>	<p>1. For the jobs performed in the Data Centre check the following:
a. procedures have been established to ensure that all changes to the job schedules are appropriately approved
b. list of people who have been assigned authority to approve changes to job schedule
c. automated job scheduling is used
d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made.
e. Procedures are established to	Mandatory	IT CA Rules SCHEDULE II 8.2			

		maintain logs of system activities
f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment
g. Procedures are implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system
</p>					
3.1.6.48	<p>Procedures shall be established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment
</p>	<p>1. For the jobs performed in the Data Centre check the following:
a. procedures have been established to ensure that all changes to the job schedules are appropriately approved
b. list of people who have been assigned authority to approve changes to job schedule
c. automated job scheduling is used
d. Procedures are established to ensure that only authorized and correct job stream and parameter changes are made.
e. Procedures are established to maintain logs of system activities
f. Procedures are established to ensure that people other than well-trained computer operators are prohibited from operating the computer equipment
g. Procedures are	Mandatory	IT CA Rules SCHEDULE II 8.2			

		implemented to ensure the secure storage or distribution of all outputs/reports, in accordance with procedures defined by the owners for each system					
--	--	--	--	--	--	--	--

3.1.7. Disaster Recovery

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Incident and Compromise Handling Procedures							
3.1.7.1	An incident management plan shall be developed and approved by the management. The plan shall include the following areas: • Certifying Authority's certification key compromise; • Hacking of systems and network; • Breach of physical security; • Infrastructure availability; • Fraudulent registration and generation of Digital Signature Certificates; and • Digital Signature Certificate suspension and revocation information.	1. Obtain copy of the incident management plan 2. Verify the plan has been approved by the management 3. Validate the plan includes the areas mentioned in the control description	Mandatory	IT CA Rules SCHEDULE III 11.3			
3.1.7.2	An incident response action plan shall be established to ensure the readiness of the Certifying Authority to respond to incidents. The plan should include the following areas: • Compromise control; • Notification to user community; (if applicable) • Revocation of affected Digital Signature Certificates; (if applicable) • Responsibilities of personnel handling incidents; • Investigation of service disruption; • Service	1. Verify an incident response action plan has been established by the CA 2. Validate the plan includes the areas mentioned in the control description	Mandatory	IT CA Rules SCHEDULE III 11.3			

	restoration procedure; • Monitoring and audit trail analysis; and </p><p>• Media and public relation </p>						
3.1.7.3	A formal security incident reporting procedure exists setting out the actions to be taken on receipt of an incident report. This includes a definition and documentation of assigned responsibilities and escalation procedures. Any incidents are reported to PA as a matter of urgency. 	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis 	Mandatory	WebTrust 3.5.9			
3.1.7.4	Users of CA systems are required to note and report observed or suspected security weaknesses in, or threats to, systems or services as they are detected. 	<p>1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and	Mandatory	WebTrust 3.5.10			

		documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis					
3.1.7.5	Procedures exist and are followed for reporting hardware and software malfunctions.	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e.	Mandatory	WebTrust 3.5.11			

		Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis					
3.1.7.6	Procedures exist and are followed to assess that corrective action is taken for reported incidents	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis	Mandatory	WebTrust 3.5.12			

3.1.7.7	A formal problem management process exists that allows the types, volumes and impacts of incidents and malfunctions to be documented, quantified and monitored	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected. d. Procedure exist and are implemented for reporting hardware and software malfunctions e. Procedures exist and are followed to assess that corrective action is taken for reported incidents f. formal problem management process and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis	Mandatory	WebTrust 3.5.13			
3.1.7.8	Procedures for identifying, reporting and resolving problems, such as nonfunctioning of Certifying Authority's system; breaches in Information Technology security; and hacking, shall be established and communicated to all personnel concerned. It shall include emergency procedures. Periodic reports shall be submitted for management review	1. Verify the security incident reporting procedure and check the following: a. Procedure details actions to be taken on receipt of an incident report b. definition and documentation of assigned responsibilities and escalation procedures exist c. procedures have been established for reporting observed or	Mandatory	IT CA Rules Section II 22			

		suspected security weaknesses in, or threats to, systems or services as they are detected.
d. Procedure exist and are implemented for reporting hardware and software malfunctions
e. Procedures exist and are followed to assess that corrective action is taken for reported incidents
f. formal problem management process and procedure exist
g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis
</p>					
3.1.7.9	<p>A help desk shall be set up to assist users in the resolution of problems. A system for recording, tracking and reporting the status of reported problems shall be established to ensure that they are promptly managed
and resolved with minimal impact on the user of the computing resources
</p>	<p>1. Verify the security incident reporting procedure and check the following:
a. Procedure details actions to be taken on receipt of an incident report
b. definition and documentation of assigned responsibilities and escalation procedures exist
c. procedures have been established for reporting observed or suspected security weaknesses in, or threats to, systems or services as they are detected.
d. Procedure exist and are implemented for reporting hardware and software malfunctions
e. Procedures exist and are followed to assess that corrective action is taken for reported incidents
f. formal problem management process	Mandatory	IT CA Rules Section II 22			

		and procedure exist g. help desk is set up to assist users in the resolution of problems. Check tickets raised on helpdesk and their resolution on sample basis					
Recovery Procedure							
3.1.7.10	Commitment shall be obtained in writing from computer equipment and supplies vendors to replace critical equipment and supplies within a specified period of time following a destruction of the computing facility.	1. Validate the recover procedure is documented and implemented 2. Verify written commitment in form of a contract has been taken from computer equipment and supplies vendors to replace critical equipment and supplies within a specified period of time following a destruction of the computing facility. 3. Check the business continuity plan includes procedures for emergency ordering of equipment and availability of services 4. Verify need for backup hardware is evaluated in accordance to business needs	Mandatory	IT CA Rules SCHEDULE II 24			
3.1.7.11	The business continuity plan shall be developed which inter alia include the procedures for emergency ordering of the equipment and availability of the services.	1. Validate the recover procedure is documented and implemented 2. Verify written commitment in form of a contract has been taken from computer equipment and supplies vendors to replace critical equipment and supplies within a specified period of time following a destruction of the computing facility. 3. Check the business	Mandatory	IT CA Rules SCHEDULE II 24			

		continuity plan includes procedures for emergency ordering of equipment and availability of services 4. Verify need for backup hardware is evaluated in accordance to business needs </p>					
3.1.7.12	The need for backup hardware and other peripherals should be evaluated in accordance to business needs 	1. Validate the recover procedure is documented and implemented 2. Verify written commitment in form of a contract has been taken from computer equipment and supplies vendors to replace critical equipment and supplies within a specified period of time following a destruction of the computing facility. 3. Check the business continuity plan includes procedures for emergency ordering of equipment and availability of services 4. Verify need for backup hardware is evaluated in accordance to business needs 	Mandatory	IT CA Rules SCHEDULE II 24			
Emergency Preparedness							
3.1.7.13	Emergency response procedures for all activities connected with computer operation shall be developed and documented. These procedures should be reviewed periodically 	1. Verify emergency response procedure has been developed and documented 2. Validate emergency drills are held periodically 	Mandatory	IT CA Rules SCHEDULE II 23			
3.1.7.14	Emergency drills should be held periodically to ensure that the documented emergency procedures are effective. 	<p>1. Verify emergency response procedure has been developed and documented 2. Validate emergency	Mandatory	IT CA Rules SCHEDULE II 23			

		drills are held periodically </p>					
Disaster Recovery/Management							
3.1.7.15	<p>Disaster recovery plan shall be developed, properly documented, tested and maintained to ensure that in the event of a failure of the information system or destruction of the facility, essential level of service will be provided. The disaster recovery framework should include:
• emergency procedures, describing the immediate action to be taken in case of a major incident
• fall back procedure, describing the actions to be taken to relocate essential activities or support services to a backup site
• restoration procedures, describing the action to be taken to return to normal operation at the original site
</p>	<p>1. Obtain copy of the documented disaster recovery plan and check the following:
a. Plan has been tested and maintained to ensure service will be provided in case of an emergency
b. The DR framework includes requirements covered in control 3.1.7.15
c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16
d. Specific disaster management plan is present for critical applications
e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster
f. Each component/aspect of the plan has a person and a backup assigned to its execution
g. Periodic training of personnel and users associated with computer system and network is conducted
h. Test plan has been developed and documented
i. Results of tests are documented for management review</p><p>j. DR plan is updated regularly
</p>	Mandatory	IT CA Rules SCHEDULE II 26			
3.1.7.16	<p>The documentation should include:
•	<p>1. Obtain copy of the documented	Mandatory	IT CA Rules SCHEDULE			

	definition of a disaster;
• condition for activating the plan;
• stages of a crisis;
• who will make decisions in the crisis
• role of individuals for each component of the plan;
• composition of the recovery team; and
• decision making process for return to normaloperation
</p>	disaster recovery plan and check the following:
a. Plan has been tested and maintained to ensure service will be provided in case of an emergency
b. The DR framework includes requirements covered in control 3.1.7.15
c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16
d. Specific disaster management plan is present for critical applications
e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster
f. Each component/aspect of the plan has a person and a backup assigned to its execution
g. Periodic training of personnel and users associated with computer system and network is conducted
h. Test plan has been developed and documented
i. Results of tests are documented for management review</p><p>j. DR plan is updated regularly
</p>		II 26			
3.1.7.17	<p>Specific disaster management plan for critical applications shall be developed, documented, tested and maintained on a regular basis.
</p>	<p>1. Obtain copy of the documented disaster recovery plan and check the following:
a. Plan has been tested and maintained to ensure service will be provided in case	Mandatory	IT CA Rules SCHEDULE II 26			

		of an emergency
b. The DR framework includes requirements covered in control 3.1.7.15
c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16
d. Specific disaster management plan is present for critical applications
e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster
f. Each component/aspect of the plan has a person and a backup assigned to its execution
g. Periodic training of personnel and users associated with computer system and network is conducted
h. Test plan has been developed and documented
i. Results of tests are documented for management review</p><p>j. DR plan is updated regularly
</p>					
3.1.7.18	<p>Responsibilities and reporting structure shall be clearly defined which will take effect immediately on the declaration of a disaster
</p>	<p>1. Obtain copy of the documented disaster recovery plan and check the following:
a. Plan has been tested and maintained to ensure service will be provided in case of an emergency
b. The DR framework includes requirements covered in control 3.1.7.15
c. The	Mandatory	IT CA Rules SCHEDULE II 26			

		documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16
d. Specific disaster management plan is present for critical applications
e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster
f. Each component/aspect of the plan has a person and a backup assigned to its execution
g. Periodic training of personnel and users associated with computer system and network is conducted
h. Test plan has been developed and documented
i. Results of tests are documented for management review</p><p>j. DR plan is updated regularly
</p>					
3.1.7.19	<p>Each component/aspect of the plan should have a person and a backup assigned to its execution
</p>	<p>1. Obtain copy of the documented disaster recovery plan and check the following:
a. Plan has been tested and maintained to ensure service will be provided in case of an emergency
b. The DR framework includes requirements covered in control 3.1.7.15
c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and	Mandatory	T CA Rules SCHEDULE II 26			

		requirements covered in control 3.1.7.16
d. Specific disaster management plan is present for critical applications
e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster
f. Each component/aspect of the plan has a person and a backup assigned to its execution
g. Periodic training of personnel and users associated with computer system and network is conducted
h. Test plan has been developed and documented
i. Results of tests are documented for management review</p><p>j. DR plan is updated regularly
</p>					
3.1.7.20	<p>Periodic training of personnel and users associated with computer system and network should be conducted defining their roles and responsibilities in the event of a disaster
</p>	<p>1. Obtain copy of the documented disaster recovery plan and check the following:
a. Plan has been tested and maintained to ensure service will be provided in case of an emergency
b. The DR framework includes requirements covered in control 3.1.7.15
c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16
d. Specific disaster management plan is present for critical applications
e.	Mandatory	IT CA Rules SCHEDULE II 26			

		Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each component/aspect of the plan has a person and a backup assigned to its execution g. Periodic training of personnel and users associated with computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly					
3.1.7.21	Test plan shall be developed, documented and maintained. Periodic tests shall be carried out to test the effectiveness of the procedures in the plan. The results of the tests shall be documented for management review	1. Obtain copy of the documented disaster recovery plan and check the following: a. Plan has been tested and maintained to ensure service will be provided in case of an emergency b. The DR framework includes requirements covered in control 3.1.7.15 c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16 d. Specific disaster management plan is present for critical applications e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster f. Each	Mandatory	IT CA Rules SCHEDULE II 26			

		component/aspect of the plan has a person and a backup assigned to its execution
g. Periodic training of personnel and users associated with computer system and network is conducted
h. Test plan has been developed and documented
i. Results of tests are documented for management review</p><p>j. DR plan is updated regularly
</p>					
3.1.7.22	<p>Disaster recovery plan should be updated regularly to ensure its continuing Effectiveness
</p>	<p>1. Obtain copy of the documented disaster recovery plan and check the following:
a. Plan has been tested and maintained to ensure service will be provided in case of an emergency
b. The DR framework includes requirements covered in control 3.1.7.15
c. The documentation covers definition of disaster, condition for activating plan, stage of crisis, decision making process and requirements covered in control 3.1.7.16
d. Specific disaster management plan is present for critical applications
e. Responsibilities and reporting structure is clearly defined and will take effect immediately on the declaration of a disaster
f. Each component/aspect of the plan has a person and a backup assigned to its execution
g. Periodic training of personnel and users	Mandatory	IT CA Rules SCHEDULE II 26			

		associated with computer system and network is conducted h. Test plan has been developed and documented i. Results of tests are documented for management review j. DR plan is updated regularly					
Compromise and Disaster Recovery							
3.1.7.23	The Certifying Authority must establish business continuity procedures that outline the steps to be taken in the event of the corruption or loss of computing and networking resources, nominated website, repository, software and/or data. Where a repository is not under the control of the Certifying Authority, the Certifying Authority must ensure that any agreement with the repository provides for business continuity procedures.	1. Verify the CA has established business continuity procedures 2. Validate the procedures cover the requirements mentioned in control description	Mandatory	IT CA Rules SCHEDULE III 11.1			
Secure facility after a natural or other type of disaster							
3.1.7.24	The Certifying Authority must establish a disaster recovery plan outlining the steps to be taken to re-establish a secure facility in the event of a natural or other type of disaster. Where a repository is not under the control of the Certifying Authority the Certifying Authority must ensure that any agreement with the repository provides that a disaster recovery plan be established and documented by the repository.	1. Validate the CAs DR plan covers steps to be taken to re-establish a secure facility in the event of a natural or other type of disaster 2. Verify in case the repository is not under CAs control, CA has signed an agreement with the repository provider that a disaster recovery plan be established and documented by the repository	Mandatory	IT CA Rules SCHEDULE III 11.2			

3.1.8. Audit Logging

Control	Control	Audit Checks	Control	References	Compliance	Document	Rem
---------	---------	--------------	---------	------------	------------	----------	-----

No.			Type				
Retention Period for Audit Logs and Archive							
3.1.8.1	The Certifying Authority must retain its audit logs onsite for at least twelve months	1. Verify on sample basis CA retains audit logs onsite for at least twelve months 2. Validate process has been established original media cannot retain the data for the required period, a mechanism to periodically transfer the archived data to new media is defined by the archive site	Mandatory	IT CA Rules SCHEDULE III 9.3			
3.1.8.2	If the original media cannot retain the data for the required period, a mechanism to periodically transfer the archived data to new media shall be defined by the archive site.	1. Verify on sample basis CA retains audit logs onsite for at least twelve months 2. Validate process has been established original media cannot retain the data for the required period, a mechanism to periodically transfer the archived data to new media is defined by the archive site	Mandatory	X.509 Policy 5.5.2			
Audit Logging							
3.1.8.3	The CA and each Delegated Third Party shall record details of the actions taken to process a certificate request and to issue a Certificate, including all information generated and documentation received in connection with the certificate request; the time and date; and the personnel involved. The CA shall make these records available to its Qualified Auditor as proof of the CA's compliance with these Requirements.	1. Verify on sample basis the CA records details of the actions taken to process a certificate request and to issue a Certificate 2. Validate security audit logs for activities that are core to CAs operations are automatically collected 3. Check all security audit logs, both electronic and non-electronic, are retained and made available during compliance audits	Mandatory	CA Browser Forum 5.4.1			
3.1.8.4	Where possible, the security audit logs shall be automatically collected. Where this is not possible, a logbook, paper form, or other physical mechanism shall be used	1. Verify on sample basis the CA records details of the actions taken to process a certificate request and to issue a Certificate 2. Validate security audit logs for activities that are core to CAs operations are automatically collected 3. Check all security audit logs, both electronic and non-electronic, are retained and made available during compliance audits	Mandatory	X.509 Policy 5.4			

3.1.8.5	The Certifying Authority must maintain secure and reliable records and logs for activities that are core to its operations and review them regularly to detect any anomaly in the system..All security audit logs, both electronic and non-electronic, shall be retained and made available during compliance audits	1. Verify on sample basis the CA records details of the actions taken to process a certificate request and to issue a Certificate 2. Validate security audit logs for activities that are core to CAs operations are automatically collected 3. Check all security audit logs, both electronic and non-electronic, are retained and made available during compliance audits	Mandatory	X.509 Policy 5.4, IT Regulations 3			
Types of Events Recorded							
3.1.8.6	To facilitate decision-making, all agreements and correspondence relating to services provided by Certifying Authority should be collected and consolidated, either electronically or manually, at a single location.	1. Verify the CA collects and consolidates electronically or manually, security information which may not be generated by his system such as covered in control 3.1.8.10 2. Verify all agreements and correspondence relating to services provided by CA are collected and consolidated, either electronically or manually, at a single location.	Mandatory	IT CA Rules SCHEDULE III 9.1			
3.1.8.7	The Certifying Authority shall maintain record of all events relating to the security of his system. The records should be maintained in audit log file and shall include such events as: - System start-up and shutdown; - Certifying Authority's application start-up and shutdown; - Attempts to create, remove, set passwords or change the system - privileges of the PKI Master Officer, PKI Officer, or PKI Administrator; - Changes to keys of the Certifying Authority or any of his other details; - Changes to Digital Signature Certificate creation policies, e.g. validity period; - Login and logoff attempts; - Unauthorised attempts at network access to the Certifying Authority's system; - Unauthorised attempts to access system files; - Generation of own keys; - Creation and revocation of Digital Signature Certificates; - Attempts to initialize remove,	1. For sample audit log files, check the following details are recorded: a. System start-up and shutdown; b. CA's application start-up and shutdown; c. Attempts to create, remove, set passwords or change the system d. privileges of the PKI Master Officer, PKI Officer, or PKI Administrator; e. Changes to keys of the CA or any of his other details; f. Changes to DSC creation policies g. Login and logoff attempts; h. Unauthorised attempts at network access i. Unauthorised attempts to access system files; j. Generation of own keys; k. Creation and revocation of DSC; l. Attempts to initialize remove, enable, and disable subscribers, and update and recover their keys; m. Failed read-and-write operations on the Digital Signature Certificate and Certificate Revocation List	Mandatory	IT CA Rules SCHEDULE III 9.1			

	enable, and disable subscribers, and update and recover their keys; • Failed read-and-write operations on the Digital Signature Certificate and Certificate Revocation List (CRL) directory </p>	(CRL) directory </p>					
3.1.8.8	CA and Subscriber Certificate lifecycle management events, including the following shall be recorded: • Certificate requests, renewal, and re-key requests, and revocation; • All verification activities stipulated in these Requirements and the CA's Certification Practice Statement; • Date, time, phone number used, persons spoken to, and end results of verification telephone calls; • Acceptance and rejection of certificate requests; Issuance of Certificates; and • Generation of Certificate Revocation Lists and OCSP entries 	1. On a sample basis validate the CA and Subscriber Certificate lifecycle management events, including the following are recorded: a. Certificate requests, renewal, and re-key requests, and revocation; b. All verification activities stipulated in these Requirements and the CA's Certification Practice Statement; c. Date, time, phone number used, persons spoken to, and end results of verification telephone calls; d. Acceptance and rejection of certificate requests; e. Issuance of Certificates; and f. Generation of Certificate Revocation Lists and OCSP entries 	Mandatory	CA Browser Forum 5.4.1			
3.1.8.9	All security auditing capabilities of the CA, CSP, and RA operating system and the CA, CSP, and RA applications required by this CP shall be enabled 	1. Verify all security auditing capabilities of the CA, CSP, and RA operating system and the CA, CSP, and RA applications required by this CP are enabled 	Mandatory	X.509 Policy 5.4.1			
3.1.8.10	A Certifying Authority should consider the use of automated security management and monitoring tools providing an integrated view of the security situation at any point in time. Records of the following application transactions shall be maintained: • Registration; • Certification; • Publication; • Suspension; and • Revocation. 	1. Verify CA has implemented automated security management and monitoring tools providing an integrated view of the security situation at any point in time 2. Validate records of application transactions as mentioned in control 3.1.8.7 are maintained 3. Check the records and log files are reviewed regularly for the activities mentioned in control 3.1.8.8 4. Verify all logs contain date and time of the event and the identity of subscriber/ subordinate/ entity which caused the event 	Mandatory	IT CA Rules SCHEDULE III 9.1			
3.1.8.11	<p>Records and log files shall be reviewed regularly	<p>1. Verify CA has implemented automated	Mandatory	IT CA Rules SCHEDULE			

	for the following activities: • Misuse; • Errors; • Security violations; • Execution of privileged functions; • Change in access control lists; • Change in system configuration </p>	security management and monitoring tools providing an integrated view of the security situation at any point in time 2. Validate records of application transactions as mentioned in control 3.1.8.7 are maintained 3. Check the records and log files are reviewed regularly for the activities mentioned in control 3.1.8.8 4. Verify all logs contain date and time of the event and the identity of subscriber/ subordinate/ entity which caused the event </p>		III 9.1			
3.1.8.12	All logs, whether maintained through electronic or manual means, should contain the date and time of the event, and the identity of the subscriber/subordinate/ entity which caused the event 	1. Verify CA has implemented automated security management and monitoring tools providing an integrated view of the security situation at any point in time 2. Validate records of application transactions as mentioned in control 3.1.8.7 are maintained 3. Check the records and log files are reviewed regularly for the activities mentioned in control 3.1.8.8 4. Verify all logs contain date and time of the event and the identity of subscriber/ subordinate/ entity which caused the event 	Mandatory	IT CA Rules SCHEDULE III 9.1			
3.1.8.13	A Certifying Authority should also collect and consolidate, either electronically or manually, security information which may not be generated by his system, such as: • Physical access logs; • System configuration changes and maintenance; • Personnel changes; • Discrepancy and compromise reports; • Records of the destruction of media containing key material, activation data, or personal subscriber information 	1. Verify the CA collects and consolidates electronically or manually, security information which may not be generated by his system such as covered in control 3.1.8.10 2. Verify all agreements and correspondence relating to services provided by CA are collected and consolidated, either electronically or manually, at a single location. 	Mandatory	IT CA Rules SCHEDULE III 9.1			
3.1.8.14	<p>Log entries shall include the following elements: • Date and time of entry; • Identity of the person making the journal entry; and •	<p>1. For sample log entries, check the following are recorded: a. Date and time of entry; b. Identity of the person making the	Mandatory	CA Browser Forum 5.4.1			

	Description of the entry. </p>	journal entry; and c. Description of the entry. </p>					
3.1.8.15	The audit record shall include the following (either recorded automatically or manually for each auditable event): • The type of event, • The date and time the event occurred• Success or failure where appropriate, and • The identity of the entity and/or operator that caused the even 	1. For sample audit records, check the following are included: a. The type of event, b. The date and time the event occurred, c. Success or failure where appropriate, and d. The identity of the entity and/or operator that caused the even 	Mandatory	X.509 Policy 5.4.1			
Frequency of Processing Audit Logs							
3.1.8.16	The Certifying Authority must ensure that its audit logs are reviewed by its personnel at least once every two weeks and all significant events are detailed in an audit log summary. Such reviews should involve verifying that the log has not been tampered with, and then briefly inspecting all log entries, with a more thorough investigation of any alerts or irregularities in the logs. Action taken following these reviews must be documented 	1. Verify the CA audit logs are reviewed by its personnel at least once every two weeks and all significant events are detailed in an audit log summary 2. Verify audit logs are reviewed at least every 30 days to examine significant sample of security audit data generated by the CA, CSP since the last review 3. Verify the Audit Administrator explains all significant events in an audit log summary 	Mandatory	IT CA Rules SCHEDULE III 9.2			
3.1.8.17	Audit logs shall be reviewed at least once every 30 days. Statistically Significant sample of security audit data generated by the CA, CSP, or RA since the last review shall be examined (where the confidence intervals for each category of security audit data are determined by the security ramifications of the category and the availability of tools to perform such a review), as well as a reasonable search for any evidence of malicious activity. 	1. Verify the CA audit logs are reviewed by its personnel at least once every two weeks and all significant events are detailed in an audit log summary 2. Verify audit logs are reviewed at least every 30 days to examine significant sample of security audit data generated by the CA, CSP since the last review 3. Verify the Audit Administrator explains all significant events in an audit log summary 	Mandatory	X.509 Policy 5.4.2			
3.1.8.18	<p>The Audit Administrator shall explain all significant events in an audit log summary. Actions taken as a result of reviews involving verifying that the log has not been tampered with, there is no discontinuity or other loss of audit data, and then briefly	<p>1. Verify the CA audit logs are reviewed by its personnel at least once every two weeks and all significant events are detailed in an audit log summary 2. Verify audit logs are reviewed at least every 30 days to examine significant sample of	Mandatory	X.509 Policy 5.4.2			

	inspecting all log entries shall be documented. </p>	security audit data generated by the CA, CSP since the last review 3. Verify the Audit Administrator explains all significant events in an audit log summary </p>					
Protection of Audit Logs							
3.1.8.19	The electronic audit log system must include mechanisms to protect the log files from unauthorized viewing, modification, and deletion. Manual audit information must be protected from unauthorised viewing, modification and destruction 	1. Verify the electronic audit log system include mechanisms to protect the log files from unauthorized viewing, modification, and deletion 2. Check the system has been configured to ensure only authorized people read and archive audit logs 3. Validate if it is acceptable for the system to over-write audit logs after they have been backed up and archived by asking the CA for practical demonstration 	Mandatory	IT CA Rules SCHEDULE III 9.4			
3.1.8.20	System configuration and procedures shall be implemented together to ensure that: • Only authorized people have read access to the logs; • Only authorized people may archive audit logs; and, • Audit logs are not modified. 	1. Verify the electronic audit log system include mechanisms to protect the log files from unauthorized viewing, modification, and deletion 2. Check the system has been configured to ensure only authorized people read and archive audit logs 3. Validate if it is acceptable for the system to over-write audit logs after they have been backed up and archived by asking the CA for practical demonstration 	Mandatory	X.509 Policy 5.4.4			
3.1.8.21	It shall be acceptable for the system to over-write audit logs after they have been backed up and archived 	1. Verify the electronic audit log system include mechanisms to protect the log files from unauthorized viewing, modification, and deletion 2. Check the system has been configured to ensure only authorized people read and archive audit logs 3. Validate if it is acceptable for the system to over-write audit logs after they have been backed up and archived by asking the CA for practical demonstration 	Mandatory	X.509 Policy 5.4.4			
Records Archival							
3.1.8.22	<p>Digital Signature Certificates stored and	<p>Verify the following are stored for at least seven	Mandatory	IT CA Rules SCHEDULE			

	generated by the Certifying Authority must be retained for at least seven years after the date of its expiration. This requirement does not include the backup of private signature keys. Public Key Certificates and Certificate Revocation Lists must be archived for a minimum period of seven years to enable verification of past transactions	years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and secondary sites have security controls in place 4. Verify all information pertaining to CA's operation, Subscriber's application, verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA		III 10, IT Regulations 3			
3.1.8.23	Audit information, subscriber agreements, verification, identification and authentication information in respect of subscriber shall be retained for at least seven years	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and secondary sites have security controls in place 4. Verify all information pertaining to CA's operation,	Mandatory	IT CA Rules SCHEDULE III 10			

		Subscriber's application, verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA					
3.1.8.24	A second copy of all information retained or backed up must be stored at three locations within the country including the Certifying Authority site and must be protected either by physical security alone, or a combination of physical and cryptographic protection. These secondary sites must provide adequate protection from environmental threats such as temperature, humidity and magnetism. The secondary site should be reachable in few hours	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and secondary sites have security controls in place 4. Verify all information pertaining to CA's operation, Subscriber's application, verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA	Mandatory	IT CA Rules SCHEDULE III 10			
3.1.8.25	All information pertaining to Certifying Authority's operation,	Verify the following are stored for at least seven years a. DSC stored and	Mandatory	IT CA Rules SCHEDULE III 10			

	Subscriber's application, verification, identification, authentication and Subscriber agreement shall be stored within the country. This information shall be taken out of the country only with the permission of Controller and where a properly constitutional warrant or such other legally enforceable document is produced	generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and secondary sites have security controls in place 4. Verify all information pertaining to CA's operation, Subscriber's application, verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA						
3.1.8.26	Information stored off-site must be periodically verified for data integrity	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and secondary sites have security controls in place 4. Verify all information pertaining to CA's operation, Subscriber's application,	Mandatory	IT CA Rules SCHEDULE III 10				

		verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA					
3.1.8.27	CA, CSP, and RA archive records shall be sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA	Verify the following are stored for at least seven years a. DSC stored and generated by CA after the date of expiration b. Public Key certificates c. Certificate Revocation List d. Audit information e. subscriber agreements f. verification, identification and authentication information in respect of subscriber 2. Validate a second copy of all information retained or backed up is stored at three locations within the country including the CA site 3. Check the primary and secondary sites have security controls in place 4. Verify all information pertaining to CA's operation, Subscriber's application, verification, identification, authentication and Subscriber agreement is stored within the country and taken out of country only with CCA's permission 5. Verify information stored off-site is periodically verified for data integrity 6. On a sample basis verify archived records are sufficiently detailed to establish the proper operation of the component or the validity of any certificate (including those revoked or expired) issued by the CA	Mandatory	X.509 Policy 5.5.1			
Protection of Archive							
3.1.8.28	No unauthorized user shall be permitted to write to,	1. Verify only authorized users are permitted to write	Mandatory	X.509 Policy 5.5.3			

	modify, or delete the archive. For the CA and CSP, the authorized individuals are Audit Administrators. For the RA, authorized individuals are someone other than the RA (e.g., Information Assurance Officer or IAO).	to, modify, or delete the archive 2. Validate the contents of archives are not released 3. Check the archive media are stored in a safe, secure storage facility separate from the component (CA, CSP) with physical and procedural security controls equivalent or better than those for component. Verify the number of times such request to share individual record was made and the record of subscriber was released to his/ her satisfaction					
3.1.8.29	The contents of the archive shall not be released except as determined by the CCA, the Licensed CA, or as required by law. Records of individual may be released upon request of any subscribers involved in the transaction or their legally recognized agents.	1. Verify only authorized users are permitted to write to, modify, or delete the archive 2. Validate the contents of archives are not released 3. Check the archive media are stored in a safe, secure storage facility separate from the component (CA, CSP) with physical and procedural security controls equivalent or better than those for component. Verify the number of times such request to share individual record was made and the record of subscriber was released to his/ her satisfaction	Mandatory	X.509 Policy 5.5.3			
3.1.8.30	Archive media shall be stored in a safe, secure storage facility separate from the component (CA, CSP, or RA) with physical and procedural security controls equivalent or better than those for component	1. Verify only authorized users are permitted to write to, modify, or delete the archive 2. Validate the contents of archives are not released 3. Check the archive media are stored in a safe, secure storage facility separate from the component (CA, CSP) with physical and procedural security controls equivalent or better than those for component. Verify the number of times such request to share individual record was made and the record of subscriber was released to his/ her satisfaction	Mandatory	X.509 Policy 5.5.3			
Requirements for Time-Stamping of Records							
3.1.8.31	The Certifying Authority shall provide Time Stamping Service for its subscribers. Error of the Time Stamping clock shall not be more than	1. Verify the VA provides time stamping service for its subscribers with error of the Time Stamping clock less than 1 in	Mandatory	X.509 Policy 5.5.5, IT Regulations 3			

	1 in 109. Archived records shall be time stamped such that order of events can be determined </p>	109 . 2. Validate on a sample basis that logs in the archive are time stamped </p>					
Procedures to Obtain & Verify Archive Information							
3.1.8.32	Procedures detailing how to create, verify, package, and transmit archive information shall be published in the applicable CPS. 	1. Verify for archived information, procedures have been established to perform following activities: a. Creation b. Verification c. Packaging d. Transmission 	Mandatory	X.509 Policy 5.5.7			
Audit Trails and Verification							
3.1.8.33	Transactions that meet exception criteria shall be completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements. 	Mandatory	IT CA Rules SCHEDULE II 10			
3.1.8.34	<p>Adequate audit trails shall be captured and certain information needed to determine sensitive events and pattern analysis that would indicate possible fraudulent use of the system (e.g. repeated unsuccessful logons, access attempts over a series of days) shall be	<p>1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is	Mandatory	IT CA Rules SCHEDULE II 10			

	analyzed. This information includes such information as who, what, when, where, and any special information such as: • Success or failure of the event • Use of authentication keys, where applicable	analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.					
3.1.8.35	Automated or manual procedures shall be used to monitor and promptly report all significant security events, such as accesses, which are out-of pattern relative to time, volume, frequency, type of information asset, and redundancy. Other areas of analysis include: • Significant computer system events (e.g. configuration updates, system crashes) • Security profile changes • Actions taken by computer operations, system administrators, system programmers, and/or security administrators	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.	Mandatory	IT CA Rules SCHEDULE II 10			
3.1.8.36	The real time clock of the computer system shall be set accurately to ensure the	1. Verify on sample basis the transactions that meet exception criteria are	Mandatory	IT CA Rules SCHEDULE II 10			

	accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases.	completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.					
3.1.8.37	The real time clock of the computer or communications device shall be set to Indian Standard Time (IST). Further there shall be a procedure that checks and corrects drift in the real time clock.	1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction 2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system 3. Verify automated or manual procedures are used to monitor and promptly report all significant security events 4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases. 5. Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two	Mandatory	IT CA Rules SCHEDULE II 10			

		years or longer depending on specific record retention requirements. </p>					
3.1.8.38	<p>Computer system access records shall be kept for a minimum of two years, in either hard copy or electronic form. Records, which are of legal nature and necessary for any legal or regulation requirement or investigation of criminal behavior, shall be retained as per laws of the land
</p>	<p>1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction
2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system
3. Verify automated or manual procedures are used to monitor and promptly report all significant security events
4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases.
5. Check computer system access records are kept for a minimum of two years
6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.
</p>	Mandatory	IT CA Rules SCHEDULE II 10			
3.1.8.39	<p>Computer records of applications transactions and significant events must be retained for a minimum period of two years or longer depending on specific record retention requirements.
</p>	<p>1. Verify on sample basis the transactions that meet exception criteria are completely and accurately highlighted and reviewed by personnel independent of those that initiate the transaction
2. Check audit trails are captured and sensitive information is analyzed to check for indicate possible fraudulent use of the system
3. Verify automated or manual procedures are used to monitor and promptly report all significant security events
4. Validate real time clock of the computer system is set accurately to ensure the accuracy of audit logs, which may be required for investigations or as evidence in legal or disciplinary cases.
5.	Mandatory	IT CA Rules SCHEDULE II 10			

		Check computer system access records are kept for a minimum of two years 6. Verify computer records of applications transactions and significant events are retained for a minimum period of two years or longer depending on specific record retention requirements.					
Audit Log Backup Procedures							
3.1.8.40	Audit logs and audit summaries must be backed up or copied if in manual form.	1. Validate audit logs and summaries are backed up and copied if in manual form	Mandatory	IT CA Rules SCHEDULE III 9.5			
Vulnerability Assessments							
3.1.8.41	Events in the audit process are logged, in part, to monitor system vulnerabilities. The Certifying Authority must ensure that a vulnerability assessment is performed, reviewed and revised, if necessary, following an examination of these monitored events.	1. Verify the events in the audit process are logged, in part, to monitor system vulnerabilities	Mandatory	IT CA Rules SCHEDULE III 9.6			

3.1.9. Compliance Audit and Other Assessments

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Frequency or circumstances of assessment							
3.1.9.1	The period during which the CA issues Certificates shall be divided into an unbroken sequence of audit periods. An audit period must NOT exceed one year in duration.	1. Verify the annual audits are conducted by the CA 2. Validate CA conducted a point-in-time readiness assessment before issuing Publicly-Trusted Certificates in case a valid audit report did not exist 3. Check the following: a. Point-in-time readiness assessment was completed no earlier than twelve (12) months prior to issuing Publicly- Trusted Certificates b. It was followed by a complete audit within ninety (90) days of issuing the first	Mandatory	CA Browser Forum 8.1			

		Publicly- Trusted Certificate. </p>					
3.1.9.2	If the CA does not have a currently valid Audit Report indicating compliance with the applicable audit schemes, then, before issuing Publicly-Trusted Certificates, the CA shall successfully complete a point-in-time readiness assessment performed in accordance with applicable standards.
</p>	1. Verify the annual audits are conducted by the CA
2. Validate CA conducted a point-in-time readiness assessment before issuing Publicly-Trusted Certificates in case a valid audit report did not exist
3. Check the following:
a. Point-in-time readiness assessment was completed no earlier than twelve (12) months prior to issuing Publicly- Trusted Certificates
b. It was followed by a complete audit within ninety (90) days of issuing the first Publicly- Trusted Certificate.
</p>	Mandatory	CA Browser Forum 8.1			
3.1.9.3	The point-in-time readiness assessment shall be completed no earlier than twelve (12) months prior to issuing Publicly- Trusted Certificates and shall be followed by a complete audit under such scheme within ninety (90) days of issuing the first Publicly-Trusted Certificate.
</p>	1. Verify the annual audits are conducted by the CA
2. Validate CA conducted a point-in-time readiness assessment before issuing Publicly-Trusted Certificates in case a valid audit report did not exist
3. Check the following:
a. Point-in-time readiness assessment was completed no earlier than twelve (12) months prior to issuing Publicly- Trusted Certificates
b. It was followed by a complete audit within ninety (90) days of issuing the first Publicly- Trusted Certificate.
</p>	Mandatory	CA Browser Forum 8.1			
Identity/qualifications of assessor							
3.1.9.4	The CA's audit shall be performed by a Qualified Auditor. A Qualified Auditor means a natural person, Legal Entity, or group of	1. Validate that the audit was performed by only by the CCA empaneled agency and
auditors.
2. Check the auditor is be	Mandatory	CA Browser Forum 8.2			

	natural persons or Legal Entities that collectively possess the following qualifications and skills: - Independence from the subject of the audit - The ability to conduct an audit that addresses the criteria specified in an Eligible Audit Scheme - Employs individuals who have proficiency in examining Public Key Infrastructure technology, information security tools and techniques, information technology and security auditing, and the third party attestation function; - For audits conducted in accordance with any one of the ETSI standard, accredited in accordance with ISO 17065 applying the requirements specified in ETSI EN 319 403; - For audits conducted in accordance with the WebTrust standard, licensed by WebTrust - Bound by law, government regulation, or professional code of ethics; and - Except in the case of an Internal Government Auditing Agency, maintains Professional Liability/Errors	independent of the CA being audited					
Assessor's relationship to assessed entity							
3.1.9.5	The auditor shall be a firm, which is independent from the entity being audited. The Controller shall determine whether an auditor meets this requirement	1. Verify the auditor is a firm, independent from CA 2. Validate the CCA verifies auditor meets above requirement	Mandatory	CA Browser Forum 8.3, X.509 Policy 8.3			
Topics covered by assessment							
3.1.9.6	CAs shall have a compliance audit mechanism in place to ensure that the requirements of this CP	1. Obtain details of the compliance audit mechanism to verify requirements of this CP and applicable CPS are	Mandatory	CA Browser Forum 8.4, X.509 Policy 8.4			

	and applicable CPS are being implemented and enforced. </p>	being implemented and enforced </p>					
Actions taken as a result of deficiency							
3.1.9.7	When the auditor finds a discrepancy between how the CA is designed or is being operated or maintained, and the requirements of this CP, or the applicable CPS, the auditor shall take the following actions: • The auditor shall note the discrepancy; • The auditor shall notify the audited CA; and • The auditor shall notify the office of CCA. 	1. For sample discrepancies raised by the auditor, verify the following actions were taken by the auditor: a. auditor noted discrepancy; b. The auditor notified the audited CA; and c. The auditor notified the office of CCA. 	Mandatory	CA Browser Forum 8.5, X.509 Policy 8.5			
Communication of results							
3.1.9.8	An Audit Report, including identification of corrective measures taken or being taken by the CA, shall be provided to the Controller (in case of grant of license and its renewal) and the audited CA (in case of annual audit). The report shall identify the versions of the CP and CPS used in the assessment 	1. Verify the audit reports are submitted to CCA and the audited CA 2. Validate the report identifies the versions of the CP and CPS used in the assessment 	Mandatory	CA Browser Forum 8.6, X.509 Policy 8.6			

3.1.10. Licensing of Certifying Authorities

Control No.	Control	Audit Checks	Control Type	References	Compliance	Document	Remarks
Licensing of CA Authorities							
3.1.10.1	To ensure the integrity of its digital certificates, the Certifying Authority shall ensure the use of approved security controls in the certificate management processes, i.e. certificate registration, generation, issuance, publication, renewal, suspension, revocation and archival 	<p>1. Verify the CA uses approved security controls in the certificate management processes, i.e. certificate registration, generation, issuance, publication, renewal, suspension, revocation and archival 2. Check the method of verification of the	Mandatory	IT Regulations 3 3			

		identity of the applicant of a Public Key Certificates commensurate with the level of assurance accorded to the certificate </p>					
3.1.10.2	<p>The following persons may apply for grant of a license to issue Digital Signature Certificates, namely:-
• an individual, being a citizen of India and having a capital of five crores of rupees or more in his business or profession;
• a company having– o paid up capital of not less than five crores of rupees; and o net worth of not less than fifty crores of rupees
• a firm having – o capital subscribed by all partners of not less than five crores of rupees; and o net worth of not less than fifty crores of rupees
• Central Government or a State Government or any of the Ministries or Departments, Agencies or Authorities of such Governments.
</p>	<p>1. Verify the following:
a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met
b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable).
c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission
d. validity of license is defined for five years from date of issue
e. license is not transferable or heritable
f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act
g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and	Mandatory	IT CA Rules 8, IT Regulations 3			

		continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits </p><p>i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period. </p>					
3.1.10.3	The applicant being an individual, or a company, or a firm under sub-rule shall submit a performance bond or furnish a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as may be approved by the Controller for an amount of 50 lakhs/ 01 crore of rupees and the performance bond or banker's guarantee shall remain valid for a period of six years from the date of its submission 	<p>1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01 crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke	Mandatory	IT CA Rules 8			

		or suspend the license in accordance with the provisions of the Act
g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license
remains valid.
h. CA subjects itself to periodic audits
</p><p>i. CA ensures confidentiality of subscriber information
j. CA complies with every order or direction issued by the Controller within the stipulated period.
</p>					
3.1.10.4	<p>The license shall be valid for a period of five years from the date of issue. The license shall not be transferable or heritable
</p>	<p>1. Verify the following:
a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met
b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable).
c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee	Mandatory	IT Regulations 3			

		remains valid for a period of six years from the date of its submission
d. validity of license is defined for five years from date of issue
e. license is not transferable or heritable
f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act
g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license
remains valid.
h. CA subjects itself to periodic audits
</p><p>i. CA ensures confidentiality of subscriber information
j. CA complies with every order or direction issued by the Controller within the stipulated period.
</p>					
3.1.10.5	<p>The Controller can revoke or suspend the licence in accordance with the provisions of the Act
</p>	<p>1. Verify the following:
a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met
b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable).
c. applicant submitted a performance bond or furnished a	Mandatory	IT Regulations 3			

		banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.					
3.1.10.6	The Certifying Authority shall be bound to comply with all the parameters against which it was audited prior to issue of licence and shall consistently and	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are	Mandatory	IT Regulations 3			

	continuously comply with those parameters during the period for which the licence shall remain valid.	met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within					
--	---	---	--	--	--	--	--

		the stipulated period. </p>					
3.1.10.7	<p>The Certifying Authority shall subject itself to periodic audits to ensure that all conditions of the licence are consistently complied with by it. As the cryptographic components of the Certifying Authority systems are highly sensitive and critical, the components must be subjected to periodic expert review to ensure their integrity and assurance.
</p>	<p>1. Verify the following:
a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met
b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable).
c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission
d. validity of license is defined for five years from date of issue
e. license is not transferable or heritable
f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act
g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license
remains	Mandatory	IT Regulations 3			

		valid. h. CA subjects itself to periodic audits </p><p>i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period. </p>					
3.1.10.8	The Certifying Authority shall always assure the confidentiality of subscriber information 	<p>1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply	Mandatory	IT Regulations 3			

		with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.					
3.1.10.9	The Certifying Authority shall comply with every order or direction issued by the Controller within the stipulated period.	1. Verify the following: a. applicant requirements or grant of license mentioned in description of control 3.1.10.1 are met b. For licence renewal audit and annual audit, verify the continued maintenance of net worth by CA in the last 5 years(if applicable). c. applicant submitted a performance bond or furnished a banker's guarantee from a scheduled bank in favour of the Controller in such form and in such manner as approved by the Controller for an amount of 50 lakhs/ 01crore rupees and the performance bond or banker's guarantee remains valid for a period of six years from the date of its submission d. validity of license is defined for five	Mandatory	IT Regulations 3			

		years from date of issue e. license is not transferable or heritable f. Controller has the authority to revoke or suspend the license in accordance with the provisions of the Act g. CA is bound to comply with all the parameters against which it was audited prior to issue of license and consistently and continuously complies with those parameters during the period for which the license remains valid. h. CA subjects itself to periodic audits i. CA ensures confidentiality of subscriber information j. CA complies with every order or direction issued by the Controller within the stipulated period.					
3.1.10.10	The method of verification of the identity of the applicant of a Public Key Certificates shall be commensurate with the level of assurance accorded to the certificate.	1. Verify the CA uses approved security controls in the certificate management processes, i.e. certificate registration, generation, issuance, publication, renewal, suspension, revocation and archival 2. Check the method of verification of the identity of the applicant of a Public Key Certificates commensurate with the level of assurance accorded to the certificate	Mandatory	IT Regulations 3			

Annual Audit Period

<p>No active annexure found for user: UCCA20250037</p>

Internal Audit Details

<p>No active annexure found for user: UCCA20250037</p>

eKYC Account Audit Details

<p>No active annexure found for user: UCCA20250037</p>

eKYC Account Based Verification

<p>No active annexure found for user: UCCA20250037</p>

RA Audit Details

<p>No active annexure found for user: UCCA20250037</p>

Court Cases

<p>No active annexure found for user: UCCA20250037</p>

Revocation Main

<p>No active annexure found for user: UCCA20250037</p>

Crypto Token

<p>No active annexure found for user: UCCA20250037</p>

CA Software Web Main

<p>No active annexure found for user: UCCA20250037</p>

Location Main

<p>No active annexure found for user: UCCA20250037</p>

CA Service Main

<p>No active annexure found for user: UCCA20250037</p>

ASP Details

<p>No active annexure found for user: UCCA20250037</p>

Public Information

<p>No active annexure found for user: UCCA20250037</p>

Certificate Cost

<p>No active annexure found for user: UCCA20250037</p>

Self-Assessment Main

<p>No active annexure found for user: UCCA20250037</p>

CA Software & External

<p>No active annexure found for user: UCCA20250037</p>

Downtime During Audit

<p>No active annexure found for user: UCCA20250037</p>

CA Trusted Persons

<p>No active annexure found for user: UCCA20250037</p>

Sumit Kumar Sharma

Java Full Stack Developer

✉ sumitsharma56@gmail.com

☎ +91 6388956241

🌐 linkedin.com/in/sumit-sharma-28948617a

📍 Delhi, India

PROFILE SUMMARY

Results-driven Full-Stack Software Engineer with **3+ years** of experience crafting scalable, secure applications. Expertise in **Java-based** backend development using Spring Boot and **microservices**, coupled with proficiency in **Angular, React.js** for dynamic frontend solutions. Proven track record of optimizing performance, implementing robust security measures, and delivering high-quality software within Agile environments. Adept at translating complex requirements into efficient, user-centric designs. Seeking a challenging role to leverage my full-stack capabilities in creating innovative software solutions that drive business growth.

PROFESSIONAL SUMMARY

Java Full Stack Developer

2022 – present | Delhi, India

Center for Development of Advanced Computing

- Spearheaded end-to-end development of a secure communication platform, from requirement analysis to successful deployment, achieving **100% functional acceptance** from the client.
- Architected and implemented a robust backend solution from scratch, utilizing **Java/J2EE**, Spring Boot, and **Spring Security** with JWT, resulting in a scalable and maintainable codebase.
- Designed and implemented a sophisticated **multi-database architecture**, successfully integrating and managing two separate SQL databases(**Oracle & Postgresql**) within a single project, enhancing data segregation and security.
- Developed a comprehensive User Management system with **Two-Factor Authentication**, significantly enhancing application security and user account protection.
- Engineered and integrated **WebSocket** functionality, enabling **real-time notifications** and improving overall user experience and engagement.
- Implemented advanced security measures for backend REST APIs, including **JWT authentication**, rigorous **input validation**, and data encryption, achieving a **95% reduction** in security vulnerabilities.
- Established a culture of code quality, achieving **90% code coverage** through comprehensive **unit testing**, and implementing a strict **code review** process that reduced post-deployment issues by 75%.
- Designed and implemented a centralized **exception handling** system with detailed error messaging, improving **error traceability** and resolution time by **80%**.
- Optimized application performance through strategic refactoring and tuning, resulting in a 40% improvement in response times under high load conditions.
- Implemented a robust error handling and **logging system**, increasing system reliability and reducing debugging time by 50%.
- Played a key role in Agile development processes, actively participating in **sprint planning**, daily stand-ups, and retrospectives, contributing to consistent **on-time delivery** of project milestones.
- **Successfully deployed** version 0.2 to the client environment, **meeting all functional requirements** and receiving positive stakeholder feedback.
- Built and optimized **scalable web applications** using **Angular**, leveraging two-way data binding, dependency injection, and **reusable components** for efficiency.
- **Implemented** advanced features like **reactive forms**, **custom directives**, and **lazy loading** to enhance application performance and maintainability.
- **Developed interactive user interfaces** with React.js, utilizing **hooks**, **context API**, and **Redux** for efficient state management.
- Integrated REST APIs, implemented **component-based architecture**, and ensured **cross-browser compatibility** for seamless user experiences.

EDUCATION

Post Graduation Diploma (Advanced Computing)

Centre for Development of Advanced Computing (CDAC)

Delhi, India

Bachelor of Technology (Computer Science)

Dr. A.P.J. Abdul Kalam Technical University

Lucknow, India

SKILLS

Programming Language :

C, C++, core java, Java/J2EE (Expert), HTML/CSS (Proficient), Shell Scripting, JavaScript (Proficient)

Frameworks and Tools:

Spring Boot, Spring Security, Maven,JWT, RESTful Web Services,Rest API, JPA, Hibernate, Angular

Technical Skills:

Data Structures, Algorithms, Microservices, Design Pattern, Agile (Scrum/Kanban), API Documentation, Problem Solving, Debugging

Development Tools:

Git, GitLab, GitHub, Docker, CI/CD, JUnit, Mockito, Selenium, Jenkins, Postman, Swagger, Apache Tomcat

Cloud & DevOps:

AWS (Familiar), Terraform (Familiar), Cloud Foundry (Familiar)

Database Management:

Postgresql, Oracle, MySQL, NoSQL[HBase](Familiar)

Soft skills:

Communication-Skill , Interpersonal-Skill , Innovative , Collaborative , critical thinking, decision-making , leadership skills, contributive, strong written and verbal communication, presentation skills

PROJECTS

Project 1 - Licensing of Certifying Authorities and Dashboard

2024 – present

CCA, GoI

Developed a comprehensive software solution to manage applications for the grant of a license to operate as a **Certifying Authority (CA)** under the IT Act. The system streamlines and automates the end-to-end **licensing process, enhancing efficiency, transparency, and user experience** for both applicants and regulatory authorities. Automated key workflows, reducing manual effort and improving processing time by optimizing application tracking, **approvals, and compliance management**.

Project 2 - Human Resource Information System (HRIS)

2022 – 2023

National Health Mission, Jharkhand, State Government

The project aims to develop Human Resource Management (HRM, or simply HR) is a function in every organization which is **designed to increase employee performance** in aligning with employer's strategic objectives. HR is primarily focused on how people are managed within organizations, focusing on systems and policies. **HRIS Software** saves all the manual efforts and makes organizations' employee data easily accessible with just a click. **With HRIS**, employees **can easily access and update their personal data**. HR management software offers the ultimate solution, like **Employee desk and Employee self-service**, for employee satisfaction

Project 3 - Chips to Startup

2022 – 2022

Ministry of Electronics and Information Technology, GoI

The project aims to develop and maintain **the web portal and proposal management system for the department of special manpower development program** under the ministry of electronics and information technology, to meet the objective and vision of **National Policy on Electronics -2019**, an umbrella "**Chips to Startup(C2S)**" not only aims at developing Specialized Manpower in VLSI/Embedded System but **also addresses each entity of the Electronics value chain** via Specialized Manpower training, Design of application-oriented Systems and deployment by academia/ R&D organization

ACHIEVEMENTS

Tech Lead

I spearheaded the development and deployment of the CCA project, **led the team of five developers**, and **actively contributed to back-end and front-end development** using **Java, Spring Boot, Angular** under tight deadlines.

Module Lead

I got multiple **opportunities to demonstrate** in front of **officials of the Ministry of Electronics and Information Technology, GoI**

LANGUAGES

• English

• Hindi